



Improving the Comprehension of CVE Vulnerability Data for Non-Security Professionals Using RAG-Based LLM Summarisation

by

Oreoluwa Olukotun, MSc

**Dissertation submitted in partial fulfilment for the Degree of
Master of Science in Cyber Security Management**

**WMG
University of Warwick**

Submitted September 2026

Contents

1	Introduction	6
1.1	Background	6
1.2	The Shift of Security Responsibility	7
1.3	Problem Definition	8
1.4	Purpose of the Study	9
1.5	Research Question and Objectives	9
1.6	Evaluation Approach	10
1.7	Significance of the Study	11
1.8	Definitions of Key Terms	11
1.9	Organisation of the Dissertation	13
2	Literature Review	14
2.1	Background and Related Work	14
2.1.1	Comprehension Challenges in Vulnerability Assessment for Technical Non-Security Professionals	14
2.2	Security Visualization	18
2.3	Large Language Model Applications	19
2.3.1	Applications of LLMs to Vulnerability Explanation	19
2.3.2	Evidence of Improved Comprehension for Non-Experts	20
2.3.3	Retrieval-Augmented Generation and Hallucination	20
2.3.4	LLM Risks and Limitations	21
2.3.5	Combining LLMs with Visualization	21
2.4	Research Gap	21

2.4.1	The Integration Gap	22
2.4.2	The Evaluation Gap	22
3	Methodology	25
3.1	Introduction	25
3.2	Research Design	25
3.3	Data Collection and Preparation	26
3.4	Data Analysis	29
3.4.1	Prompt Design	29
3.4.2	Automated Text Metrics	29
3.4.3	LLM-as-judge	30
3.4.4	Human comprehension study	30
3.5	Reliability and Validity	31
3.6	Ethical Considerations	31
4	Findings and Evaluation	32
4.1	Introduction	32
4.2	Automated Text Metrics	32
4.2.1	Readability	33
4.2.2	Closeness to the source	34
4.2.3	Length and the difference between prompts	34
4.3	Independent Judge Scores	35
4.3.1	Comprehension Support	36
4.3.2	Faithfulness	36
4.3.3	Scoring Reliability	37
4.4	Human Study	38
4.4.1	Participants	38
4.4.2	Comprehension Accuracy	38
4.4.3	Comprehension by Familiarity with Vulnerability Information	40
4.4.4	Clarity and Confidence	41

4.5	Summary of Findings	41
5	Discussion	43
A	Corpus and Evaluation Sample Data	44
B	Findings and Evaluation Supplementary Data	46
	Bibliography	50

List of Figures

3.1	Data pipeline from raw NVD feeds to the indexed retrieval corpus.	27
3.2	Evaluation sampling matrix, four CVEs per cell.	28
4.1	Dale-Chall readability scores for the raw NVD descriptions, persona summaries and baseline summaries. Lower is easier.	33
4.2	Per-CVE change in Dale-Chall score from raw NVD description to summary.	34
4.3	Word count of the persona and baseline summaries. The persona summaries are longer.	35
4.4	Independent judge comprehension support scores for the three texts (GPT-4.1, temperature 0, mean of three passes).	36
4.5	Per-CVE change in faithfulness score from the description-only reference to the description and CVSS reference, for the persona and baseline summaries.	37
4.6	Comprehension accuracy on the raw NVD descriptions and the summaries, technical-background sample ($n = 15$).	39
B.1	BERTScore F1 and precision for the persona and baseline summaries.	48
B.2	ROUGE-1, ROUGE-2 and ROUGE-L for the persona and baseline summaries.	48
B.3	Independent judge scores for comprehension support and faithfulness, across the three texts (GPT-4.1, temperature 0, mean of three passes). Faithfulness is under the description-only reference.	49
B.4	Faithfulness scores under the description and CVSS reference, for the three texts (GPT-4.1, temperature 0, mean of three passes).	49

List of Tables

2.1	Comparison of existing CVE comprehension tools against the proposed approach.	24
4.1	Comprehension accuracy by question type and condition ($n = 15$).	39
4.2	Comprehension accuracy by familiarity with vulnerability records ($n = 15$)	40
4.3	Mean clarity and confidence ratings by condition, five-point scale, technical-background sample ($n = 15$).	41
A.1	Post-filter record counts by severity (all years)	44
A.2	Record counts by year, before and after filtering	44
A.3	Corpus composition against source pool	44
A.4	Evaluation sample composition	45
A.5	Nearest-neighbour cosine distance across the 24 evaluation CVEs	45
B.1	CVEs where the summary scored a higher (harder) Dale-Chall score than the raw NVD description it was generated from.	46
B.2	Descriptive statistics for the automated metrics, both prompt conditions, across the 24 evaluation CVEs.	46
B.3	Paired differences between the persona and baseline conditions across the 24 evaluation CVEs, with paired Cohen’s d.	47
B.4	The seven text and dimension combinations that varied across the three judge passes. All other combinations scored identically on every pass. . . .	47
B.5	Independent judge scores across the 24 evaluation CVEs, both dimensions and three texts (GPT-4.1, temperature 0, mean of three passes). Faithfulness is under the description-only reference.	47

Chapter 1

Introduction

1.1 Background

With an increase in digital advancement and adoption comes an even larger threat landscape and attack surface. For each new system, software, and device that is built, there is a new flaw or vulnerability waiting to be exploited. In 2025 alone, 48,185 CVEs were reported, a 30.6% increase over the previous year, which recorded 40,009 (Afzalzada 2026). Figures for 2026 are projected to reach a median of 59,427, marking the first time the number of reported CVEs will cross the 50,000 threshold in a single year (Forum of Incident Response and Security Teams 2026).

This increase has largely been driven by the industrialisation of how vulnerabilities are reported, rather than by software becoming less secure. For one, there has been a rise in the number of CVE Numbering Authorities (CNAs), which stood at 484 as of January 2026 (Afzalzada 2026). This growth in reporting authorities and the greater thoroughness with which they operate have led directly to an increase in the volume of CVEs found and reported (Technologies 2024). Alongside the expansion of CNAs, the use of generative AI has accelerated the scale and speed at which vulnerabilities and bugs can be identified. Bug bounty platforms such as HackerOne reported a 200% increase in submissions as of 2025, driven by AI-generated vulnerability reports (Afzalzada 2026). While this increase in vulnerability discovery is generally considered positive for the security of the ecosystem, the platforms responsible for managing these vulnerabilities are left to contend with data overload, which in turn affects the quality of reported vulnerabilities.

The National Vulnerability Database (NVD), which is charged with cataloguing vulnerabilities and is widely regarded as a source of truth for vulnerability enrichment, has experienced exponential growth in its backlog. The NVD has historically been a reliable source precisely because of its enrichment process, but it has become unable to fully enrich all reported vulnerabilities and has resorted to prioritisation criteria to determine which ones

are enriched, leaving thousands of reported vulnerabilities insufficiently enriched (Afzalzada 2026). This triage method, proposed by NIST to address the CVE overwhelm, has resulted in the enrichment of only around 15% to 20% of newly reported vulnerabilities (NIST 2026). For the developers responsible for resolving these vulnerabilities, this poses a significant problem as they are faced with a greater number of vulnerabilities carrying a lower quality of information. In practice, this forces them to scour the web and other unreliable sources for fixes, which is not the best approach in the long term (Afzalzada 2026). This leads us to further understand the role of technical non-security personnel like developers as it pertains to vulnerability management.

1.2 The Shift of Security Responsibility

Developers and general IT staff who are primarily responsible for the resolution of vulnerabilities are described as technical non-security personnel, due to their lack of formal security training or secure coding training (Thomas et al. 2018). A defining characteristic of security personnel is that they are trained to think like attackers, that is, to hold an attacker mindset that makes them able to see how certain vulnerabilities might be exploited (Hibshi et al. 2016, Shimizu & Hashimoto 2026). Technical non-security personnel like developers, by contrast, are primarily focused on meeting feature requirements, which most often do not include security or hardening considerations.

Because feature requirements rarely include secure code considerations, security has historically been treated as an afterthought, left for security scanning tools to detect after coding, an approach sometimes described as "shift-right". As this proved less effective, the industry began adopting a "shift-left" approach (Veracode 2026), in which security considerations are placed earlier in the software development lifecycle, at the coding phase for which developers are primarily responsible. This has shifted the burden of security onto those with very little knowledge of secure practices. In an interview study with 32 application security experts, all participants reported that the remediation of vulnerabilities was usually performed by a developer, while security personnel typically detect the problem, and then triage and escalate it to the developers (Thomas et al. 2018).

This reliance on non-security personnel is intensifying. Organisations are increasingly depending on them for remediation because the exponential growth in the number of vulnerabilities coincides with a severe labour shortage of trained cyber security professionals (Reynolds et al. 2021, Shimizu & Hashimoto 2026). The result is a structural gap as a growing volume of vulnerabilities is being handed to a population that most often lacks the formal security education to interpret it, as most computer science programmes do not mandate security training (Thomas et al. 2018).

1.3 Problem Definition

This shift carries clear risks. Technical non-security personnel often struggle to see how a theoretical flaw or vulnerability could be exploited, which highlights a comprehension gap rather than a detection one (Thomas et al. 2018). While vulnerability scanners frequently detect these vulnerabilities, the details they provide are often not clear enough, or contain security jargon that the reader is not equipped to interpret (Jawad et al. 2024). The comprehension gap is further exacerbated when CVEs are missing essential information such as severity metrics or actionable mitigation steps, leaving a vulnerability identified but with no contextual information on how it can be exploited. Even where a severity metric is present, the CVSS score that accompanies it is a compressed numerical judgement that assumes the reader can already interpret the attack vector, exploitability, and impact conditions behind it, so for a non-security reader the score signals that a vulnerability matters without conveying why. This reduces the vulnerability to a theoretical flaw and leaves developers paralysed, holding the information but unable to act on it (Thomas et al. 2018, Smith et al. 2020). The same lack of information has driven developers to rely on unofficial guidance from peers or forums such as Stack Overflow and Reddit (Thomas et al. 2018), where they obtain code snippets but little context on how effective those snippets are for their own specific application, leading to a possible new flaw or a failure to remediate the original vulnerability at all.

The consequence of this poor comprehension is reflected in the rise of security debt and lengthening patch times, as remediation speeds have drastically slowed. As of 2025, the Veracode State of Software Security report finds that the average time to fix a software flaw has reached 252 days, and that 50% of organisations now carry security debt of critical severity (Tanis et al. 2025). The inability to properly communicate the risk of a vulnerability to a developer makes it difficult for them to take action, and so the flaw persists (Thomas et al. 2018).

Endsley’s Situational Awareness (SA) framework recognises this breakdown, between the identification of a vulnerability and the inability to properly synthesise or comprehend it, as a state of uncertain comprehension (Endsley 1995, Hibshi et al. 2016). In trying to understand the problem, developers may seek help from security experts or security platforms, which predominantly use overly technical terms, producing what Carreira et al. term the comprehension-jargon paradox (Carreira et al. 2025). In other words, the very act of seeking more information about an identified vulnerability can further exacerbate the comprehension problem, as new technical jargon is introduced rather than resolved. This produces a breakdown across the phases of comprehension (Level 2) and projection (Level 3) of the SA framework, as the developer does not fully synthesise the meaning of the vulnerability at Level 2 and is therefore unable to project its impact or take action at

Level 3, leaving them in a state of paralysis and uncertain comprehension (Hibshi et al. 2016).

The problem this study addresses is therefore not that vulnerabilities go undetected, but that the data describing them fails to translate into comprehension for the non-security personnel now responsible for acting on it. Both the free-text description and the CVSS score assume expertise the reader does not hold, and the fallback of forum-based guidance introduces further risk rather than resolving it. Addressing this requires more than surfacing raw data, it requires restructuring that data into a form that closes the Level 2 gap directly, which is the response the tool developed in this study sets out to provide.

1.4 Purpose of the Study

The same artificial intelligence that has accelerated the discovery of vulnerabilities also offers a means of addressing the comprehension gap it has helped widen. Where AI-driven discovery has increased the volume of reported vulnerabilities, large language models (LLMs) can be applied to the interpretation of those vulnerabilities, closing the distance between an identified vulnerability and a developer’s ability to comprehend and act on it.

This project develops a tool that uses a retrieval-augmented generation (RAG) pipeline to produce plain-language summaries of CVE data for technical non-security personnel. Rather than presenting raw NVD descriptions, the tool generates a structured summary for each vulnerability which includes what is vulnerable, how it can be exploited, and what action should be taken. Retrieval-augmented generation is used so that the generated summaries are grounded in authoritative source data rather than produced from the model’s parameters alone, reducing the risk of fabricated or misleading security guidance. These summaries are surfaced through an interactive dashboard, allowing a user to view the plain-language summary alongside the original NVD description and additional relevant information on the vulnerability.

The aim of this study is to determine whether such RAG-based, plain-language summarisation improves the comprehension of CVE data for technical non-security personnel when compared against the raw information currently provided by the NVD.

1.5 Research Question and Objectives

The aim of this study is to determine whether RAG-based, plain-language summarisation improves the comprehension of CVE data for technical non-security personnel when compared against the raw information currently provided by the NVD. This leads to the

central research question that the study sets out to answer.

To what extent can RAG-based LLM summarisation improve the comprehension of CVE/CVSS vulnerability data for technical non-security professionals, compared to the raw descriptions currently provided by the NVD?

Four objectives follow from this question.

1. To characterise the comprehension challenges faced by technical non-security personnel through a review of the literature.
2. To design and implement a RAG-based LLM pipeline that generates three-part plain-language CVE summaries.
3. To surface these summaries through an interactive dashboard, with links to the original NVD records for verification.
4. To evaluate whether the summaries improve comprehension relative to raw NVD descriptions, using automated metrics and a user study.

Each objective addresses a component of the research question. The first establishes what comprehension means for this population and where the raw description fails them, which the question presupposes. The second produces the intervention whose effect the question asks about. The third delivers that intervention through a working triage interface, so that comprehension is assessed under the conditions in which vulnerability data is actually encountered, while the link to the source record preserves the user’s ability to verify what a summary asserts. The fourth supplies the evidence on which the extent claimed in the question is judged.

1.6 Evaluation Approach

The central claim of this study, that plain-language summarisation improves comprehension, is evaluated against the raw descriptions currently provided by the NVD. Comprehension is treated as the primary construct and is assessed through a user study, in which participants drawn from the target population of technical non-security personnel respond to a set of CVEs presented in both raw and summarised form. Comprehension is measured objectively, through questions that target the reader’s understanding of what is vulnerable, how it could be exploited, and what action is required, and subjectively, through ratings of clarity and confidence. This directly addresses the extent to which comprehension improves, which the research question asks.

The user study is complemented by two automated measures that play a supporting role in evaluation. Readability metrics quantify the linguistic accessibility of each form of the text, and fidelity measures assess how faithfully each summary reflects its source record, which speaks to the risk of fabricated content in a security context. A separate large language model is also used as an independent judge, scoring each summary and the raw NVD description on comprehension support and faithfulness, with a judge from a different provider than the generating model to avoid a model assessing its own output. These measures characterise the summaries but do not by themselves establish comprehension, which is why the user study is treated as the primary instrument. The full evaluation design, including the sampling of CVEs, the construction of the comprehension questions, and the analysis approach, is set out in the Methodology chapter.

1.7 Significance of the Study

The significance of this study is both practical and academic. Practically, it addresses a population that has become responsible for vulnerability remediation without being equipped for it. As established above, the burden of remediation increasingly falls on technical non-security personnel, yet the information available to them is written for, and assumes the prior knowledge of, security specialists. By translating vulnerability data into plain, structured, actionable language, the tool targets the precise point at which the current workflow breaks down, the moment a developer must understand a vulnerability well enough to act on it, and offers an alternative to the unreliable forum-based guidance they currently fall back on.

Academically, the study contributes to several under-explored areas. While LLMs have been widely applied to technical text, their use in generating *trustworthy* security guidance for non-experts remains under-examined, particularly the question of whether users can and should trust AI-generated security information (Hagen et al. 2025). It also speaks to the cognitive load placed on non-experts interpreting security data and to the consequences of LLM hallucination in a domain where an incorrect remediation step carries real risk. In terms of disciplinary alignment, the work sits primarily within the Vulnerability Management and Human Factors knowledge areas of the Cyber Security Body of Knowledge (CyBOK).

1.8 Definitions of Key Terms

For clarity, the following key terms are used throughout this dissertation.

A **Common Vulnerabilities and Exposures (CVE)** record is a unique, common iden-

tifier for a publicly known cyber security vulnerability, issued under the CVE Programme whose stated mission is to identify, define, and catalog publicly disclosed cyber security vulnerabilities.¹ Each record contains a CVE identifier, a brief description of the vulnerability, and any pertinent references. It is not intended to supply remediation guidance or an assessment of risk in any particular environment.

The **Common Vulnerability Scoring System (CVSS)**, maintained by FIRST, captures the principal characteristics of a vulnerability and produces a numerical score reflecting its severity, derived from metrics covering the attack vector, attack complexity, required privileges, and the impact on confidentiality, integrity, and availability (Forum of Incident Response and Security Teams 2019). The specification states explicitly that CVSS is designed to measure severity and should not be used alone to assess risk, a distinction that carries directly into the comprehension problem examined in this study.

The **National Vulnerability Database (NVD)** is the United States government repository of standards-based vulnerability management data, maintained by NIST (National Institute of Standards and Technology 2024). It performs enrichment on records already published to the CVE List, associating Common Vulnerability Scoring System impact metrics, Common Weakness Enumeration vulnerability types, and Common Platform Enumeration applicability statements. The NVD is the primary source of vulnerability information used in this study and the baseline against which the proposed tool is evaluated.

Large Language Models (LLMs) are pre-trained language models built by training Transformer architectures over large-scale text corpora, and the term is applied to models of significant size, typically containing tens or hundreds of billions of parameters (Zhao et al. 2023). Beyond a certain parameter scale these models exhibit capabilities, such as in-context learning, that are not present in smaller language models (Zhao et al. 2023), and they have been applied across a range of cyber security tasks (de Jesus Coelho da Silva & Westphall 2024).

Retrieval-augmented generation (RAG) is an approach, introduced by Lewis et al., that combines the parametric knowledge held in a model’s weights with non-parametric knowledge retrieved from an external source, so that generated output is grounded in retrieved documents rather than in the model’s parameters alone (Lewis et al. 2020). Grounding output in retrieved records is intended to reduce the risk of fabricated content, which is a particular concern where an incorrect remediation instruction carries real security consequences.

Technical non-security personnel refers to developers, IT staff, and similar technical roles who engage with vulnerability data but lack formal security training (Thomas et al.

¹<https://www.cve.org>

2018). These users are technically capable within their own domain, which distinguishes them from general end users, but they do not hold the specialist knowledge that vulnerability data assumes of its reader. Security is frequently perceived by such audiences as scary, confusing, and dull, a perception that security professionals must actively work to overcome (Haney & Lutters 2018).

Security visualisation is an interdisciplinary field that combines the technical complexity of cyber security with visual analytics, transforming complex security data into more readily digestible visual formats (Devendra et al. 2025). Existing tools in this space are largely designed for expert users, and visualisations aimed at non-expert audiences remain comparatively underdeveloped (Devendra et al. 2025).

Situational awareness (SA) refers to Endsley’s three-level model, which defines SA as the perception of the elements in the environment within a volume of time and space, the comprehension of their meaning, and the projection of their status in the near future (Endsley 1995). Comprehension at Level 2 involves synthesising the elements perceived at Level 1 with the reader’s own knowledge in order to form an understanding of the situation. This dissertation uses the framework to locate the difficulty non-security personnel face at Level 2, where a vulnerability is perceived but not understood.

1.9 Organisation of the Dissertation

Chapter 2

Literature Review

2.1 Background and Related Work

This chapter presents a review of literature relevant to the development of an LLM-powered vulnerability comprehension tool. The review is organised into three themes. Section 2.1 examines the comprehension challenges that technical non-security professionals face when interpreting vulnerability assessment information, establishing the problem this thesis addresses. Section 2.2 reviews security visualization approaches and their role in supporting vulnerability comprehension. Section 2.3 surveys the application of large language models to vulnerability summarization and explanation. Together, these themes establish both the need for the proposed tool and the technical foundations on which it is built.

2.1.1 Comprehension Challenges in Vulnerability Assessment for Technical Non-Security Professionals

This section examines the comprehension challenges that non-security technical professionals encounter when interpreting CVE and CVSS data, drawing on Endsley’s Situational Awareness framework to position comprehension as a critical cognitive stage in security decision-making.

With companies facing numerous vulnerability alerts from static application security testing (SAST) tools and vulnerability detection tools, it is crucial that the vulnerability assessment information provided to security decision-makers and non-security professionals that implement security is comprehensible in order to enable efficient prioritisation and remediation of vulnerabilities. These tools often rely on information from vulnerability assessment frameworks like the Common Vulnerability and Exposures (CVE) and Common Vulnerability Scoring System (CVSS) information, used as a guide for vulnerability

assessments. However, research indicates that when presented with vulnerability assessment information, people without a formal security education, such as software developers with a computer science background, are significantly more likely to make evaluation errors, whereas those with a security education are 30% to 60% less likely to do so (Allodi et al. 2020).

Empirical work on security decision-making offers an insight into how vulnerability information is assessed by professionals. Hibshi et al. applied Endsley’s Situational Awareness (SA) framework to examine the cognitive behaviour of professionals when conducting vulnerability assessments, finding a recurring pattern of participants becoming stuck at the comprehension stage due to difficulties in properly synthesising the information provided (Hibshi et al. 2016). The SA framework defines three levels of cognitive processing: perception of information (Level 1), comprehension of its meaning (Level 2), and projection of its future implications (Level 3) (Hibshi et al. 2016, Endsley 1995). A failure at Level 2 directly impairs a decision maker’s ability to reach Level 3 and take informed action. Existing literature identifies several factors that exacerbate this comprehension failure, particularly for non-security technical professionals engaging with CVE and CVSS data.

Factors Affecting Non-Security Technical Professionals’ Comprehension

Presentation and Technical Jargon Issues

Critics of existing vulnerability assessment frameworks have raised concerns about the way vulnerability information is presented. The overly technical nature of how vulnerabilities are framed, combined with the abstractness behind the derivation of severity scores, has been widely criticised (Chopra et al. 2026). Research further reveals that CVSS metrics such as User Interaction, Attack Vector, and Scope lack sufficient precision and clarity, leading to inconsistent interpretations even among experienced evaluators. Users have also been found to rarely consult the official CVSS documentation, likely due to the effort required to synthesise guidance that is dispersed across multiple separate documents (Shen et al. 2025). This creates a situation where non-experts are expected to interpret technical information which they have no formal knowledge on and make critical decisions regarding security of systems.

Information Overload and External Search Behaviour

A further compounding weakness of CVE information is information overload. When users struggle to extract meaning from NVD entries, they frequently turn to external sources such as Google searches, research papers, and security reports to build a more complete understanding of a vulnerability. The process of searching for and synthesising this supplementary information significantly increases the time

required to fully assess a vulnerability, delaying remediation decisions. Crucially, security forums and informal channels, which developers commonly turn to, do not consistently offer best practice solutions, introducing the additional risk that action may be taken based on incomplete or unreliable guidance (Thomas et al. 2018).

Motivational and Knowledge Barriers

Beyond the structural limitations of the frameworks themselves, a motivational dimension compounds the comprehension problem. Research indicates that many developers possess the technical skills to build software systems but do not perceive security as their primary responsibility (Thomas et al. 2018, Schüring et al. 2025). Even where formal security training is provided, this does not consistently produce the mindset required to proactively engage with vulnerability data. This motivational gap means that even when vulnerability information is accessible, developers may not engage with it meaningfully without clear and actionable guidance. Consistent with this, studies demonstrate that developers are significantly more likely to act on vulnerability information they perceive as clear and directly relevant to their context, supporting the projection stage of the SA framework (Level 3) (Shen et al. 2025). When this condition is not met, they are prone to seek information elsewhere, often through channels where the quality of guidance cannot be assured (Galanska et al. 2025).

Overreliance on CVSS and Prioritisation Risk

A particularly consequential manifestation of the comprehension gap is the widespread overreliance on CVSS severity scores as the primary metric for vulnerability prioritisation. To effectively prioritise a vulnerability, the decision maker must first properly understand and contextualise the issue within their own environment. When this comprehension fails, organisations default to using CVSS severity scores as a proxy for prioritisation (Jacobs et al. 2021). This introduces its own risk, as CVSS scores do not account for the exploitability of a vulnerability within a specific organisational environment (Siewruk & Bondaruk 2026). Research shows that applying contextual filters such as Known Exploited Vulnerabilities (KEV) and CVSS scores together can help reduce urgent alert workload by as much as 95% to 97% (Shimizu & Hashimoto 2026), indicating that combining multiple information sources produces more actionable prioritisation outcomes than relying on severity scores alone. While EPSS offers a predictability dimension by estimating the likelihood of exploitation in the wild, its lack of transparency regarding score derivation limits confidence in its application (Shen et al. 2025). Studies further suggest that context-aware scoring, which incorporates environmental variables, provides a more accurate reflection of vulnerability severity relative to a given environment (Siewruk & Bondaruk 2026), though this remains an emerging approach.

The Subjectivity of Assessment

Compounding these challenges is the inherent subjectivity of vulnerability assessment. Research demonstrates that even among security experts, the same vulnerability can be rated differently, highlighting that inconsistency is a property of the assessment process itself rather than solely a function of user inexperience (Allodi et al. 2020). This finding is significant because it undermines the assumption that CVSS scores represent an objective ground truth, and suggests that improving comprehension alone is insufficient without also addressing the reliability of the information being interpreted. It is worth acknowledging, however, that CVSS does provide value as a standardised baseline that enables organisations to communicate vulnerability severity consistently across teams and tools (Jacobs et al. 2021), and its widespread adoption reflects its utility as a common reference point even where its limitations are recognised. These multi-dimensional comprehension challenges have prompted a range of mitigation efforts in the literature, which are reviewed in the next section.

Pre-LLM Solutions and Their Limitations

Prior attempts to address comprehension challenges focused primarily on improving information presentation rather than transforming its content. Research demonstrated that restructuring vulnerability information by breaking it into specific contextual cues, such as asset type, attack method, and vulnerability type, reduced assessment errors compared to presenting raw CVE descriptions (Allodi et al. 2018). However, the same research found that including known threat information as a cue had the opposite effect, confusing non-experts who conflated threat severity with technical severity metrics, ultimately increasing errors rather than reducing them (Allodi et al. 2018). This finding illustrates that simply providing more information is not sufficient and may in fact be counterproductive without careful structuring and contextualisation.

Security visualization approaches offered a parallel avenue for reducing information overload, replacing long-form text with interactive visual representations of vulnerability data (Watson & Lipford 2017). These approaches addressed the perception stage of the SA framework at Level 1 by making vulnerability distributions and relationships easier to scan and interpret. However, pre-LLM visualization solutions remained largely focused on data presentation and content-aware scoring frameworks, and did not address the deeper Level 2 comprehension challenge of translating technical vulnerability descriptions into plain-language, actionable guidance.

A further proposed solution involves embedding security expertise within development workflows through the use of security champions, individuals with security knowledge

who serve as translators between technical vulnerability data and the development team (Galanska et al. 2025, Haney & Lutters 2018). This approach has been found to support Level 3 situational awareness by enabling non-experts to convert vulnerability insights into actionable remediation strategies, as guidance is tailored to the team’s specific context (Galanska et al. 2025). However, critics note that suitably qualified security champions are scarce, and this model does not scale effectively across organisations (Haney & Lutters 2018). For an AI-driven tool to replicate this function, it would need to exhibit characteristics associated with trusted security advocates, including transparency, contextual relevance, and the ability to present information in accessible, non-alarmist terms (Haney & Lutters 2018, Hussain 2025).

Collectively, these findings establish that the comprehension challenges facing technical non-security professionals are multi-dimensional, spanning presentation quality, information volume, motivational barriers, scoring subjectivity, and the structural limitations of existing frameworks. Prior solutions have addressed individual dimensions in isolation without producing a comprehensive, scalable remedy. This gap motivates the approach taken in this thesis, which seeks to combine LLM-powered summarization with interactive visualization to address the comprehension and prioritisation challenges identified across the literature, with the explicit goal of supporting non-security professionals in progressing through all three levels of the SA framework from perception to informed action.

2.2 Security Visualization

Where the previous section established that comprehension fails at Level 2 of the SA framework, this section examines security visualization, an approach that has been widely proposed to help users manage vulnerability information, and considers how far it addresses that failure. Visualization has increasingly been shown to support the perception stage of situational awareness (Level 1) more effectively than the comprehension stage (Level 2), with one study reporting perception at 92.6% against comprehension at 53.7% (Jiang et al. 2022). The reason is that most dashboards simply display vulnerabilities without allowing users to drill into them, and so do little to help users understand the vulnerabilities themselves or the business impact they carry (Jiang et al. 2022). This limitation is compounded by two further issues. First, security visualizations are usually designed for security operations experts rather than non-expert users, which shapes the design of such tools in ways that do not serve the population this thesis is concerned with (Jiang et al. 2022). Second, because of the sheer volume of vulnerability information, dashboards frequently become overwhelming and cluttered (Jiang et al. 2022). Some approaches have attempted to add context rather than merely display data. Vulnerability management tooling has combined vulnerability information with an organisation’s asset

information to generate CVSS environmental scores, shifting the focus toward vulnerabilities that are critical within a specific environment and thereby making prioritisation easier (Walkowski et al. 2021). However, this approach depends on a complete and accurate asset database, which is not always available (Walkowski et al. 2021). The literature further indicates that supporting non-experts requires moving away from one-size-fits-all, technically dense, static disclosures toward adaptive, structured, and user-centric interfaces. Suggested design responses include tailoring explanations to the target audience and role (Alloza-García et al. 2025), reducing information overload through progressive disclosure at varying levels of granularity, an initial overview, detail on hover, and a dedicated pane on selection (Reynolds et al. 2021), and enabling multi-criteria filtering so users can interactively narrow the dataset (Jung et al. 2022). Crucially, however, these remain presentation and prioritisation strategies. They improve how vulnerability data is perceived, filtered, and navigated, but they do not translate the technical content of a vulnerability into plain, comprehensible language. The Level 2 comprehension gap therefore persists even in well-designed visualization tools, which motivates the combination of an interactive visualization layer with LLM-generated summarization pursued in this thesis, and reviewed in the following section.

2.3 Large Language Model Applications

The previous themes established that comprehension fails at Level 2 of the situational awareness framework, and that security visualization improves how vulnerability data is perceived and prioritised without resolving that comprehension failure. This section examines the third body of work relevant to this thesis which is the application of large language models (LLMs) to explaining and summarising software vulnerabilities, the evidence that they improve comprehension for non-experts, the role of retrieval-augmented generation (RAG) in making their output trustworthy, and the risks that accompany their use.

2.3.1 Applications of LLMs to Vulnerability Explanation

LLMs have been applied to vulnerability explanation in several forms. Although they may struggle to recall specific vulnerability details from memory, they perform well when summarising security advisories that are supplied to them directly, and do so with a low hallucination rate (McClanahan et al. 2024). This distinction is significant, as it points toward grounding the model in supplied source data rather than relying on its internal parameters, which is the principle underlying the retrieval-augmented approach adopted in this thesis.

Beyond summarisation, LLMs have been used to generate contextualised explanations. SAFE, a Static Analysis Findings Explainer, operates as a developer-facing IDE plugin that prompts GPT-4o to construct a step-by-step natural language walkthrough of a vulnerable data path, using the developer’s own variable names and code, thereby making the vulnerability easier to understand within the developer’s own environment (Johnson et al. 2025). Other systems apply LLMs to related tasks like CASEY which uses fine-tuned LLMs for automated bug triaging and CWE prediction (Torkamani et al. 2025), while further work has explored crowdsourcing explainable AI (Alloza-García et al. 2025) and auditing the usability and actionability of exploit information (Shen et al. 2025). Collectively, these show that LLMs can translate technical vulnerability data into more accessible forms, though most target developers within a coding workflow rather than a broader non-security technical audience.

2.3.2 Evidence of Improved Comprehension for Non-Experts

There is direct empirical evidence that LLM-generated material improves comprehension for non-experts. In a controlled study evaluating AI-generated secure-coding tutorials against expert-authored manuals, developers using the AI-generated reports achieved statistically superior knowledge acquisition, at 59.2% against 15.8% for the expert-written group (Schüring et al. 2025). The advantage is attributed to how the material is structured as LLMs reduce extraneous cognitive load by chunking dense, jargon-heavy prose into logically structured paragraphs with sparse bullets and interactive glossaries (Schüring et al. 2025). Comprehension is further improved through role-appropriate framing, such as using analogies the reader is already conversant with, an approach that achieved a score of 79.75 on the System Usability Scale (Alloza-García et al. 2025). This evidence directly supports the plain-language, structured summary design pursued in this thesis.

2.3.3 Retrieval-Augmented Generation and Hallucination

A central concern when applying LLMs to security information is hallucination. Retrieval-augmented generation addresses this by shifting the model’s response away from free-form probabilistic recall, which frequently triggers hallucination, toward in-context extraction and translation of retrieved source material (de Jesus Coelho da Silva & Westphall 2024, McClanahan et al. 2024). Because the output is generated from retrieved documents, RAG also provides an auditable rationale as the generated content, along with its citations, can be traced back to the reference database (de Jesus Coelho da Silva & Westphall 2024). This grounding and traceability are what make RAG suitable for a security context, where an unsupported or fabricated claim carries real consequences.

2.3.4 LLM Risks and Limitations

Despite these strengths, the use of LLMs introduces risks that are particularly acute in a security setting. The most serious is the deception of superficially fluent hallucination, where a model sounds confident while producing technically incorrect summaries (Pekarić et al. 2025); both non-experts and experts may fall prey to trusting incorrect technical information presented fluently. A related failure is the "lost in the middle" effect, where retrieval accuracy has been shown to drop by up to 50% for critical data positioned in the middle of long inputs, causing severe omissions (Chopra et al. 2026). Reliance on LLMs also encourages automation bias, whereby users trust model output without independent verification (Johnson et al. 2025), compounded by the fragile trust users place in AI systems, swinging between over-trust and outright rejection depending on the most recent result they have seen (Hagen et al. 2025). These risks motivate design choices, such as source grounding and traceable citations, that keep the user able to verify what the model produces.

2.3.5 Combining LLMs with Visualization

A small number of systems have begun to bring LLMs together with visualization or dashboard interfaces, including the SAFE plugin (Johnson et al. 2025), VulnScore (Alqahtani & Almukaynizi 2025), and the context-aware CAVP model (Jung et al. 2022). However, these largely pair LLMs or scoring mechanisms with developer tooling or prioritisation dashboards aimed at security practitioners, rather than translating vulnerability data into plain language for technical non-security personnel. This sets up the gap that the following section develops in full, which is the absence of an approach that combines LLM-based, plain-language CVE summarisation with an interactive triage dashboard designed specifically for the comprehension needs of non-security technical users.

2.4 Research Gap

The three themes reviewed in this chapter converge on a single unaddressed problem. The first theme established that the difficulty non-security personnel face with CVE and CVSS data is a failure of comprehension at Level 2 of the situational awareness framework, rather than a failure of perception. The second theme showed that security visualization improves how vulnerability data is perceived and prioritised at Level 1, but does little to resolve the underlying comprehension failure, with one study reporting perception supported at 92.6% against comprehension at only 53.7% (Jiang et al. 2022). The third theme demonstrated that large language models can translate technical vulnerability data into accessible, plain-language explanations and can measurably improve comprehension

for non-experts, yet the tools that do this are seldom directed at a non-security audience or paired with an interactive visual interface. Taken together, these themes point to an approach that neither body of work has delivered, one that combines the perceptual strengths of visualization with the explanatory strengths of large language models, for the specific benefit of technical non-security personnel.

2.4.1 The Integration Gap

CSXAI is designed to communicate security risks to non-technical end users and system administrators through a client-side dashboard, which places it close to the audience this thesis addresses. However, it does not use generative LLMs for summarisation, relying instead on static, rule-driven, knowledge-based templates, and it positions the adoption of LLMs only as a long-term goal beyond a three-year horizon (Alloza-García et al. 2025). ChatNVD approaches the problem from the opposite direction, using models such as GPT-4o Mini to generate accessible summaries of vulnerabilities drawn from the National Vulnerability Database, but it presents these through a textual chatbot rather than a multi-view visual dashboard, and its retrieval is confined to lookup and query responses (Chopra et al. 2026). SAFE applies GPT-4o to produce structured, step-by-step explanations, yet it is an IDE plugin built for software developers rather than a broader non-security audience (Johnson et al. 2025). VulnScore and similar platforms embed AI-assisted summaries within vulnerability management suites, but their dashboards are built for penetration testers, security analysts, and IT professionals and are oriented toward technical risk-score distribution rather than non-expert understanding (Alqahtani & Almukaynizi 2025). Dashboards co-designed for non-technical managers, such as the Tableau-based file activity and exfiltration dashboard, represent risk through visual comparison and timelines but lack any LLM-based summarisation or text explanation (Chung et al. 2023).

The pattern across these tools is consistent. Standard security dashboards are strong at aggregation, coordinated filtering, and network mapping but fail to provide plain-language explanations, while LLM-based tools are strong at narrative synthesis but lack the visual metrics and interactive triaging workflows of a dashboard (Jung et al. 2022). The gap this thesis addresses lies precisely at that intersection, in an interface that unites plain-language, LLM-generated CVE summaries with the filtering and overview capabilities of a visual dashboard, built for users without formal security training.

2.4.2 The Evaluation Gap

A second gap concerns how AI-generated security explanations are evaluated. Existing work assesses them using objective measures such as pre- and post-test knowledge assess-

ments and subjective measures such as the System Usability Scale adapted for explanation clarity (Schüring et al. 2025, Alloza-García et al. 2025). These are valuable, but they leave two problems unresolved that are central to this thesis.

The first is a lack of comparison against the raw source. Studies tend to evaluate AI-generated material in isolation or against expert-authored documents, rather than against the raw NVD descriptions that non-security personnel currently rely on in practice. Whether plain-language summarisation improves comprehension relative to the descriptions the NVD already provides is the specific question this thesis sets out to answer, and it remains largely untested. The second is the risk of superficial fluency. Large language models produce confident, linguistically polished summaries, and a non-expert may rate such an explanation highly for clarity or usefulness while failing to notice a subtly incorrect or hallucinated recommendation embedded within it (Chopra et al. 2026, Pekaric et al. 2025). Evaluating comprehension, therefore, requires attention not only to whether users feel they understand, but to whether that understanding is accurate.

These gaps define the contribution of this thesis. It develops a RAG-based tool that generates plain-language, three-part CVE summaries and surfaces them through an interactive dashboard for technical non-security personnel, and it evaluates whether those summaries improve comprehension when measured directly against the raw descriptions currently provided by the NVD.

Table 2.1: Comparison of existing CVE comprehension tools against the proposed approach.

Tool	LLM plain-language summarisation	Visual triage dashboard	Target audience	Evaluation baseline
ChatNVD (Chopra et al. 2026)	Yes, RAG summaries via GPT-4o Mini	No, text chatbot with query and lookup only	General users querying CVEs	Model accuracy rather than non-expert comprehension against raw NVD
SAFE (Johnson et al. 2025)	Yes, GPT-4o explanations using the developer’s own code	No, IDE plugin with no filtering or overview	Developers mid-code	In-context code clarity rather than standalone comprehension
VulnScore (Alqahtani & Almukaynizi 2025)	Partial, AI-assisted summaries inside a vulnerability-management suite	Partial, risk-score distribution views	Security teams and analysts	Patch-prioritisation performance rather than comprehension
CAVP (Jung et al. 2022)	No, context-aware scoring with no summarisation	Partial, multi-criteria filtering	Security teams prioritising	Prioritisation accuracy rather than comprehension
This study	Yes, RAG three-part plain-language summaries	Yes, filtering, overview and summary-vs-raw view	Technical non-security personnel	Comprehension against raw NVD using metrics and questionnaire

Chapter 3

Methodology

3.1 Introduction

This chapter sets out the methodology used to implement the data pipeline for the RAG context and the steps used to evaluate the summaries generated by the LLM. It describes how the vulnerability data was collected and prepared, how the retrieval corpus and evaluation sample were constructed, and how the resulting summaries were assessed against the raw NVD descriptions they are intended to improve upon. The evaluation includes three methods. The first applies automated text metrics to compare the generated summaries against the source descriptions to assess readability and semantic closeness to the source descriptions. The second uses a separate large language model as an independent judge, scoring the summary quality to avoid the bias of a model evaluating its own output. The third is a human comprehension study in which technical non-security participants answer comprehension questions on both summarised and raw vulnerability data. The chapter is organised into five sections. Section 3.2 presents the research design and the rationale behind it. Section 3.3 describes data collection and preparation. Section 3.4 sets out the analysis approach for all three evaluation methods. Section 3.5 addresses reliability and validity. Section 3.6 covers ethical considerations.

3.2 Research Design

This study builds a retrieval-augmented generation pipeline that produces plain-language summaries of vulnerability records, then evaluates those summaries against the raw NVD descriptions they are intended to improve upon. The research contribution lies in prompt design rather than model training. The underlying model weights are frozen, and the summaries are shaped entirely through in-context instruction, so the design treats the prompting technique and its produced output as the object of study.

The design has two different comparisons. The main one is between the generated summaries and the raw NVD descriptions. This is what answers the research question, whether RAG-based summaries help technical non-security readers understand CVE data better than the descriptions the NVD gives now. The secondary comparison is between the two ways of writing that summary, a plain baseline prompt and a security-champion persona prompt, informed by the literature review. This comparison addresses the best approach to present the summary for comprehension.

The two prompts are run on the same model, the same retrieved context, and the same evaluation sample. They share the same instructions, the same three-part structure, and the same four examples. The only difference is a persona preamble at the start of the persona prompt, so any difference in the results comes down to that framing alone.

The persona is tested rather than assumed because the evidence on persona prompting is mixed. Xiao et al. find that expert-role prompting helps advisory tasks that need caution and risk communication but hurts clarity and adds padding on explanatory ones, where a plain prompt does better (Xiao et al. 2026). Vulnerability summarising could go either way. The persona here is written as a trusted peer helping a non-specialist understand a risk and act on it, not as an instruction to show expertise, which places it on the favourable side of that split. Running both prompts as a controlled comparison tests this rather than assuming it.

3.3 Data Collection and Preparation

The vulnerability data used in this study was drawn from the National Vulnerability Database (NVD), using its annual JSON data feeds for the years 2020 to 2026. The REST API was attempted first but returned persistent errors and capped results per request, which made a complete and repeatable pull difficult. The annual feeds provided the full set of records for each year in a single download, giving a stable starting point of 213,085 raw CVE records.

Each record was passed through a three-part quality filter. A record was kept only if it had a CVSS version 3.1 metric, an English description of at least 100 characters, and at least one CPE entry naming an affected product. CVSS v3.1 gives every kept record the same scoring fields, and the CPE entry means each record names the software it affects, which the summaries rely on. The length floor drops records too short to summarise or embed. All three filters together left 156,084 records. The filtered pool broken down by severity and by year is given in Tables A.1 and A.2. Figure 3.1 shows the full pipeline, from the raw feeds through to the indexed corpus.

From this pool, a corpus of 12,000 records was drawn by proportional stratified random

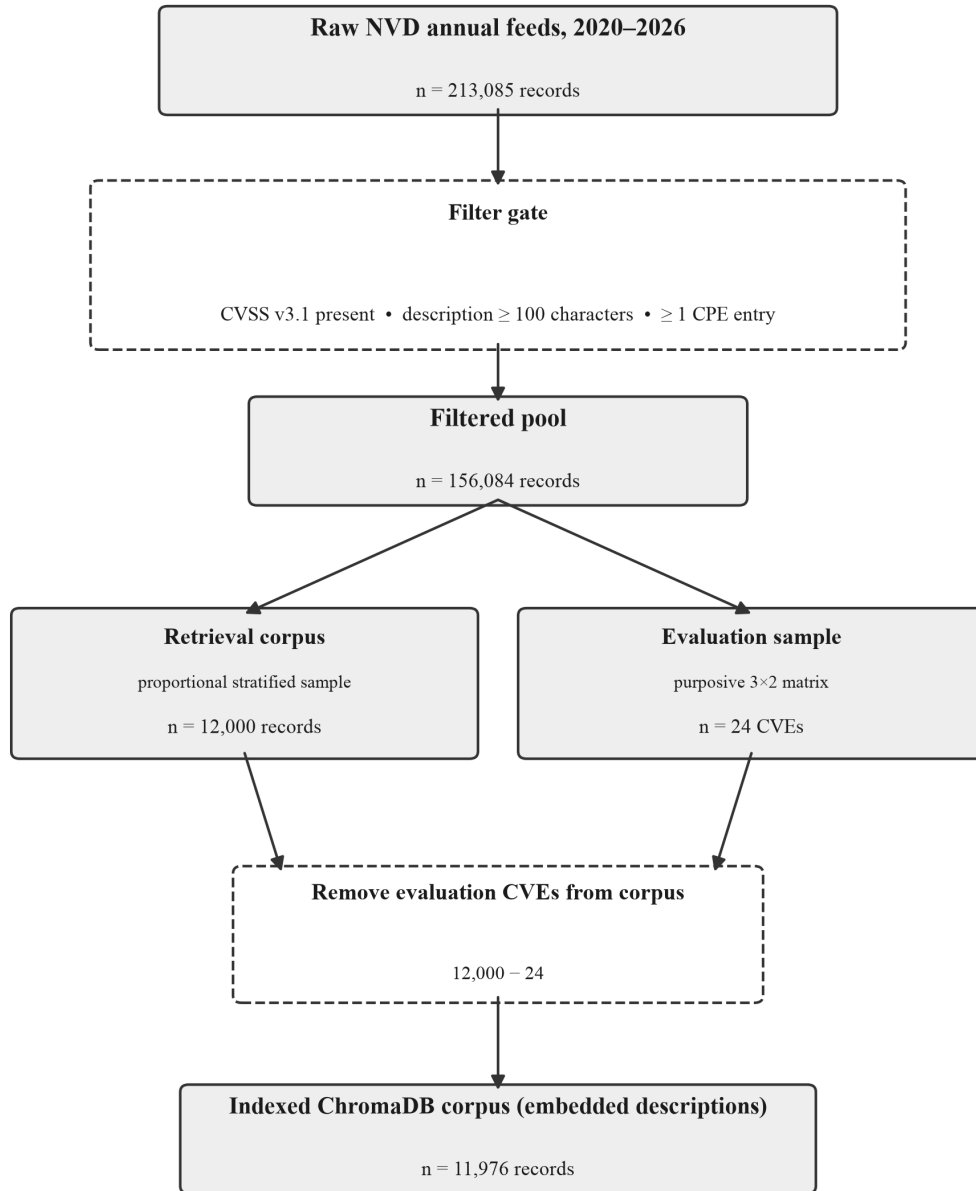
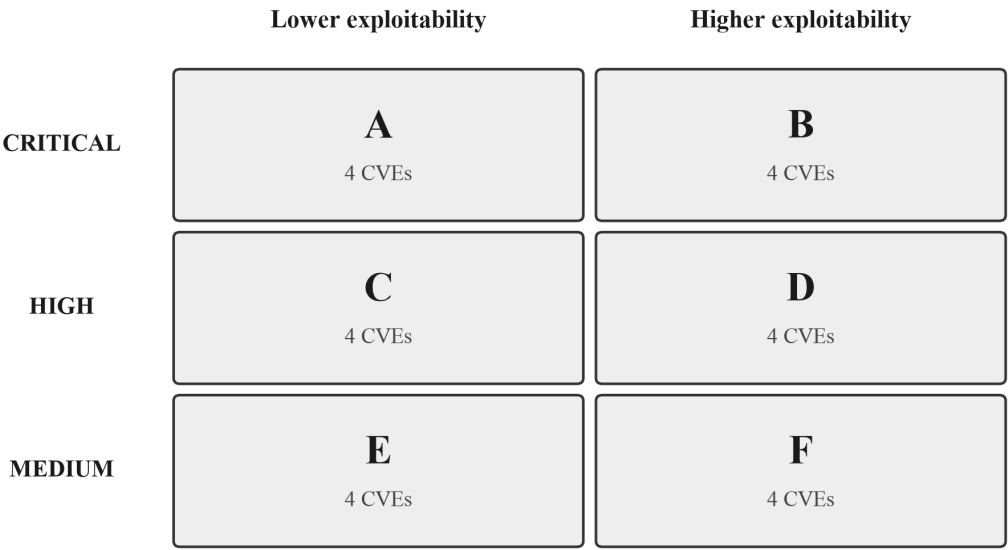


Figure 3.1: Data pipeline from raw NVD feeds to the indexed retrieval corpus.

sampling across the four severity levels, using a fixed seed so the sample can be reproduced. Sampling this way keeps the corpus in line with the real spread of severities. Table A.3 shows the corpus matches the pool proportions at each severity level. The corpus was then enriched with two exploitation signals held as metadata, membership of the CISA Known Exploited Vulnerabilities (KEV) catalogue and the Exploit Prediction Scoring System (EPSS) score.

A separate evaluation sample of 24 CVEs was chosen purposively across a matrix of three severity levels and two exploitability levels, four per cell, shown in Figure 3.2. The 24 CVEs and their properties are listed in Table A.4. These 24 were removed from the corpus before indexing, leaving 11,976, so a query CVE could not just retrieve itself as its nearest match. Each corpus description was embedded with the all-MiniLM-L6-v2 model and stored in a ChromaDB vector store, chosen because it runs locally and can filter on metadata at query time. Only the description was embedded, with the other fields kept as metadata.



Higher exploitability: EPSS ≥ 0.5 or KEV-listed. Lower exploitability: EPSS < 0.5 and not KEV-listed.

All 12 higher-exploitability records are KEV-listed.

Figure 3.2: Evaluation sampling matrix, four CVEs per cell.

3.4 Data Analysis

3.4.1 Prompt Design

The summaries are produced through in-context prompting rather than any change to the model, so the prompt is the instrument under study. Each prompt instructs the model to produce a summary in three fixed parts, covering what is vulnerable, how it can be exploited, and what action to take, written as short bullet points. This structure follows the security-champion attributes identified in the literature review, presenting the risk in a plain and non-alarmist form. The prompt also carries grounding instructions that constrain the model to the information provided in the corpus and forbid details not present in the source, a deliberate guard against hallucination.

Two prompt conditions were prepared, a baseline and a persona, held byte-identical apart from the persona preamble described in Section 3.2. Both were locked and hashed before any evaluation summaries were generated, and the model was run at temperature zero so that generation is deterministic.

3.4.2 Automated Text Metrics

The generated summaries were first assessed with automated metrics comparing each summary against its raw NVD description. The metrics measure two things, how readable the summary is and how close it stays to the source in meaning.

Readability was measured with the Dale-Chall score (Dale & Chall 1948), which works from the share of words that fall outside a list of words familiar to most readers. A lower score means easier text. It was run on both the summaries and the raw descriptions, so the two can be compared directly, with word count recorded alongside to show whether a summary gets easier while getting longer. Flesch-Kincaid (Kincaid et al. 1975) was not used, since it scores difficulty mostly by sentence and word length, which the bullet format changes on its own, so it would measure the formatting rather than the language.

Closeness to the source was measured with ROUGE (Lin 2004) and BERTScore (Zhang et al. 2020). ROUGE counts shared word sequences, so a low score is expected here, since the summaries deliberately reword the source into plainer language. BERTScore compares meaning rather than exact words, so it is read as a grounding check that the summary stays true to its source. Interpreting the scores is carried out in the Findings and Discussion chapters.

3.4.3 LLM-as-judge

The summaries were also scored by a separate language model acting as an independent judge. It came from a different provider than the model that wrote the summaries, so no model ever scored its own work, and it was run at a pinned version and temperature zero so the scoring can be repeated. The judge scored three things, the persona summary, the baseline summary, and the raw NVD description, on a one to five scale across two dimensions. Each text was scored three times on each dimension so the stability of the scores could be checked.

Comprehension support was judged from the text alone, on whether a non-security reader could tell what is vulnerable, how it is exploited, and what to do about it. Faithfulness was judged against the source, on whether the summary adds anything the source does not support. This is the judge’s estimate of comprehension support, not comprehension measured in real readers, which is what the human study does.

3.4.4 Human comprehension study

The third method is a study that measures comprehension directly with the kind of user the tool is built for. Participants are technically capable but do not work in security. They are shown vulnerability records and answer questions on them, so comprehension is measured from their answers rather than inferred from the text.

The questions target the second level of Endsley’s situational awareness model, which is comprehension of what the data means rather than just seeing it. This is the level the literature review identified as where non-experts struggle with raw vulnerability data. Each record is followed by three multiple-choice questions, covering what is vulnerable, how it is exploited, and the scope of remediation, and two Likert items on how clear and confident the reader felt.

Each participant sees both a generated summary and a raw NVD description, but never for the same CVE. The records are split into blocks and rotated across participants using a Latin square, so the order and pairing of conditions are balanced and no one sees the same vulnerability in both forms. The persona summary is used as the generated version, since it is the fuller version of the prompt design being tested.

The sample is small and the study is exploratory, so the analysis reports descriptive statistics and effect sizes rather than significance tests. Comprehension is compared between the summarised and raw conditions, with participant expertise recorded as a covariate. The study population is technical non-security personnel, so a participant who reported no technical background falls outside it. Any such response is held out of the main comparison and reported on its own.

3.5 Reliability and Validity

Several choices were made so the results can be trusted and repeated. Generation was run at temperature zero on a pinned model, and the retrieved context was frozen and reused rather than queried fresh each time, so the same input gives the same summary on a re-run. Both prompts were locked and hashed before any evaluation summaries were produced, so the exact instrument can be checked. The independent judge was pinned and run at temperature zero for the same reason.

For the human study, each participant sees both a summary and a raw description but never for the same CVE, and the records are rotated across participants with a Latin square, so order and pairing do not bias the result. Screening keeps the sample to the intended group, readers without formal security training.

Retrieval was checked before any summaries were generated, by measuring the distance from each evaluation CVE to its nearest corpus record, given in Table A.5. Some limits on validity are worth stating. The embedding model is general-purpose rather than security-tuned, which is what weakens retrieval on a small number of CVEs, and those weakly grounded cases were kept rather than dropped so the evaluation reflects real retrieval rather than an ideal one. LOW severity is absent from the evaluation set, since comprehension matters most at the higher severities. Expertise is self-reported, so it is treated as a rough covariate rather than a firm measure.

3.6 Ethical Considerations

The study was approved through the WMG Taught Student Cyber Projects route, under the supervisor’s delegated authority and the Cyber Ethics Panel.

Participation was voluntary and by informed consent. Participants were told what the study involved and how their responses would be used, and gave consent before seeing any material. A short screening step confirmed they had no formal security training, the group the study is about. The comprehension questions used forced response so an answer was always recorded, while the Likert items were left optional. All data was collected through Qualtrics.

Chapter 4

Findings and Evaluation

4.1 Introduction

This chapter reports the results of the evaluation carried out on the LLM-generated summary as described in Chapter 3. The findings are reported descriptively. Their interpretation, and the answer to the research question, is held for the Discussion chapter in Chapter 5.

The evaluation carries two comparisons. The primary comparison is between the generated summaries and the raw NVD descriptions, which is the comparison that answers the research question. The secondary comparison is between the two prompt conditions, the persona and the baseline, which tests how the summary is best written rather than whether it helps. All three methods focus on the primary comparison. The secondary comparison is carried by the automated metrics and the independent judge only, since participants in the human study see the persona summary alone.

The chapter is organised by the evaluation methods. Section 4.2 reports the automated text metrics. Section 4.3 reports the independent judge scores. Section 4.4 reports the human comprehension study. Section 4.5 draws the results together. Full result tables are given in Appendix B, and are referred to from the relevant section.

4.2 Automated Text Metrics

The generated summaries were first assessed with the automated metrics set out in Section 3.4.2. Each summary was compared against the raw NVD description of the same CVE across the full evaluation sample of 24 CVEs in both the persona and baseline conditions. The metrics measure two things, how readable the summary is and how closely it stays to the source in meaning. The results are reported here by what they measure, first

readability, then closeness to the source, then length. The favourable direction for each metric was set out in Section 3.4.2.

4.2.1 Readability

Readability was measured with the Dale-Chall score, where a lower score means easier text. The raw NVD descriptions scored a mean of 13.65. Both summary conditions scored lower, at 11.78 for the persona and 12.09 for the baseline. The improvement over the raw description was consistent and large in both conditions. Measured as a paired difference for each CVE, the persona summaries scored 1.75 points lower than their source descriptions on average, and the baseline summaries 1.69 points lower, giving paired effect sizes of $d = -1.16$ and $d = -1.18$ respectively. Figure 4.1 shows the three means side by side. Figure 4.2 shows the same result per CVE, where the readability score falls from the raw description to the summary in almost every case.

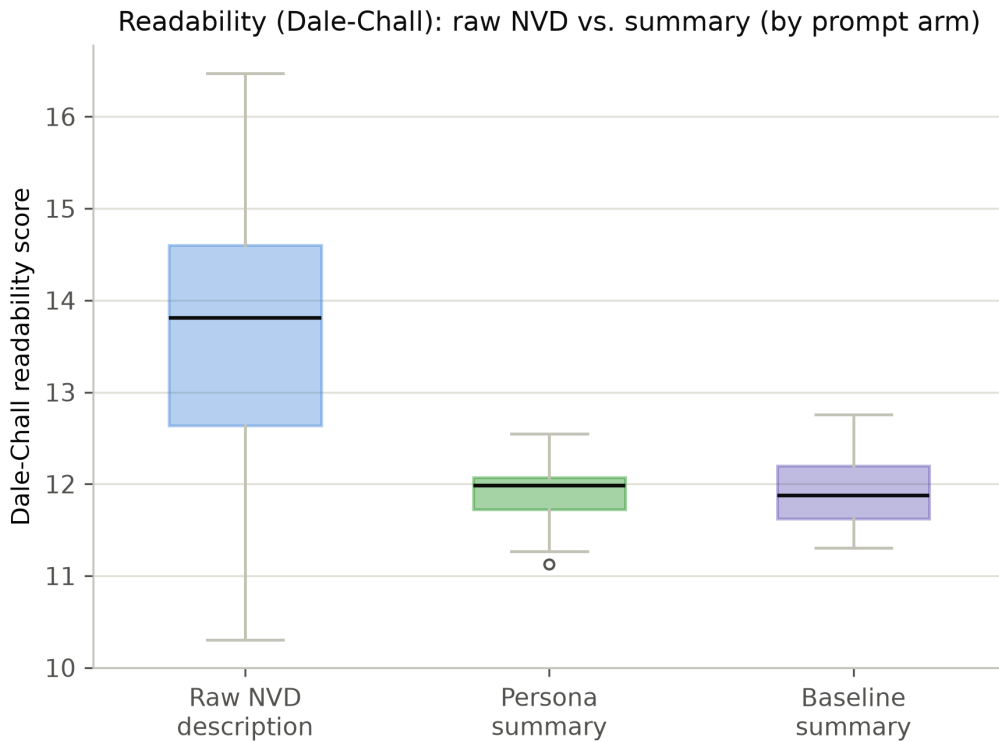


Figure 4.1: Dale-Chall readability scores for the raw NVD descriptions, persona summaries and baseline summaries. Lower is easier.

The improvement did not hold for every CVE. In 7 of the 48 summaries, the summary scored higher, making it harder to read, than the raw description it was generated from. These cases fall on three CVEs, CVE-2024-1781, CVE-2021-42013 and CVE-2022-3062, whose raw NVD descriptions were already among the most readable in the sample. The full set of regression cases is given in Table B.1.

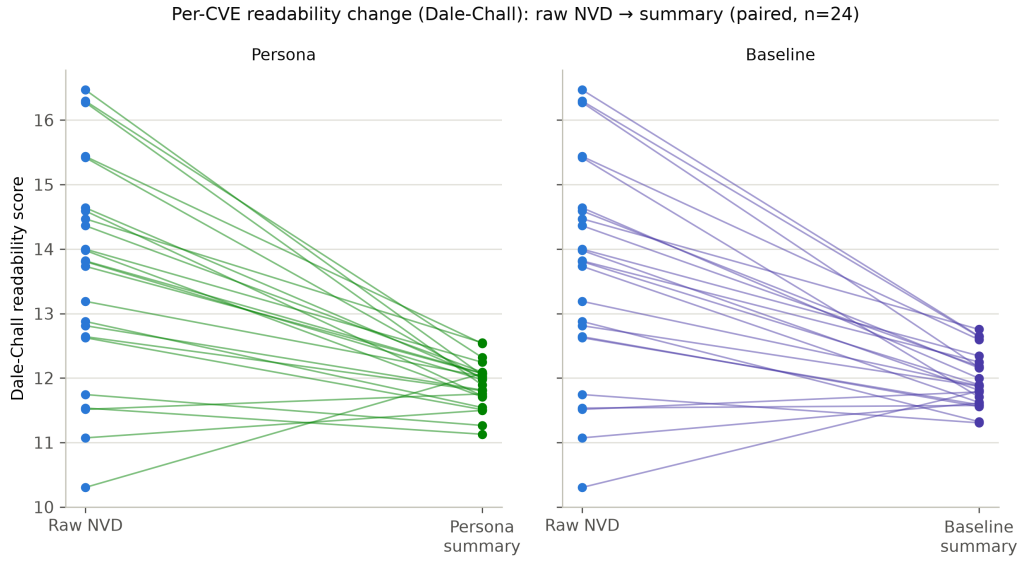


Figure 4.2: Per-CVE change in Dale-Chall score from raw NVD description to summary.

4.2.2 Closeness to the source

Closeness to the source was measured with ROUGE and BERTScore. BERTScore, which compares meaning rather than exact wording (Zhang et al. 2020), was high and tight in both conditions, at an F1 score of 0.86 for both the baseline and the persona, with a standard deviation below 0.02 in each case. ROUGE, which counts shared word sequences (Lin 2004), was low in both conditions, at a ROUGE-1 of 0.23 for the persona and 0.24 for the baseline. This combination, a low ROUGE alongside a high BERTScore, held across the whole sample. The BERTScore and ROUGE result figures are shown in Appendix B as Figure B.1 and Figure B.2 respectively.

4.2.3 Length and the difference between prompts

Word count was recorded alongside the readability score to show whether a summary became easier to read while also becoming longer. The persona summaries were longer than the baseline summaries, at a mean of 279.54 words against 266.08, a paired difference of 13.46 words and an effect size of $d = 0.74$. This was the clearest difference between the two prompt conditions. On the other metrics the two conditions were close. The paired differences between persona and baseline were small on Dale-Chall, ROUGE and BERTScore, with effect sizes at or below 0.34 in each case. The persona sat marginally further from the raw NVD wording than the baseline did. The word count results are shown in Figure 4.3. Full descriptive statistics for both conditions, and the paired persona-versus-baseline differences, are given in Tables B.2 and B.3

Flesch-Kincaid was not reported for this run. As set out in Section 3.4.2, the bullet

format makes each line a short single-clause line, which the metric would read as an easy sentence regardless of the language used, so it would measure the formatting rather than the readability.

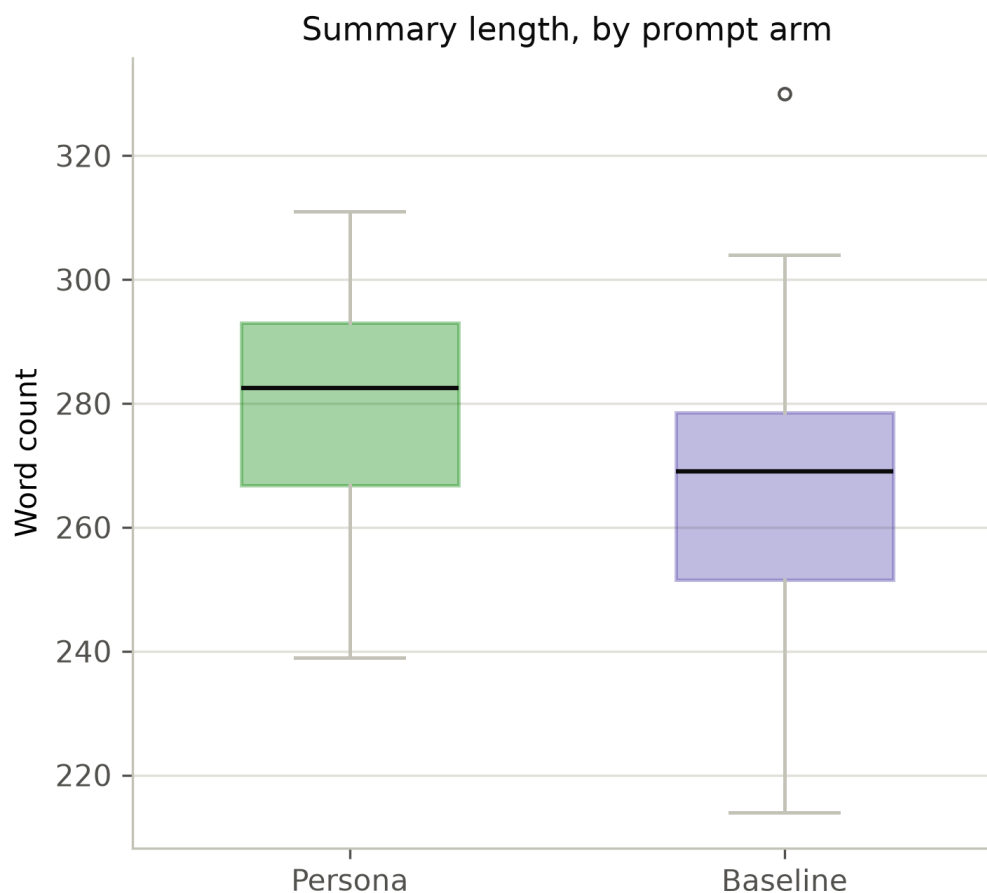


Figure 4.3: Word count of the persona and baseline summaries. The persona summaries are longer.

4.3 Independent Judge Scores

The summaries were also scored by an independent language model judge, using the design set out in Section 3.4.3. The judge was a different model from a different provider from the one that generated the summaries, which removes the risk of a model favouring its own output. It scored each text on two dimensions, comprehension support and faithfulness, on a scale of one to five. Each text was scored three times on each dimension so that the stability of the scores could be checked. Three texts were scored including the persona summary, the baseline summary and the raw NVD description.

4.3.1 Comprehension Support

Comprehension support was judged from the text alone, without sight of the source. Both summary conditions received the maximum score. The persona and baseline summaries each scored a mean of 5.00, with a standard deviation of 0.00, meaning every summary in both conditions was scored five out of five on every pass. The raw NVD descriptions scored lower, at a mean of 4.01, with a standard deviation of 0.75 and scores ranging from three to five. Measured as a paired difference against the raw description, both summary conditions scored 0.99 points higher, giving a paired effect size of $d = 1.31$ for both conditions. The two summary conditions could not be separated on this dimension, since both sat at the top of the scale. Figure 4.4 shows the comprehension scores for the three texts.

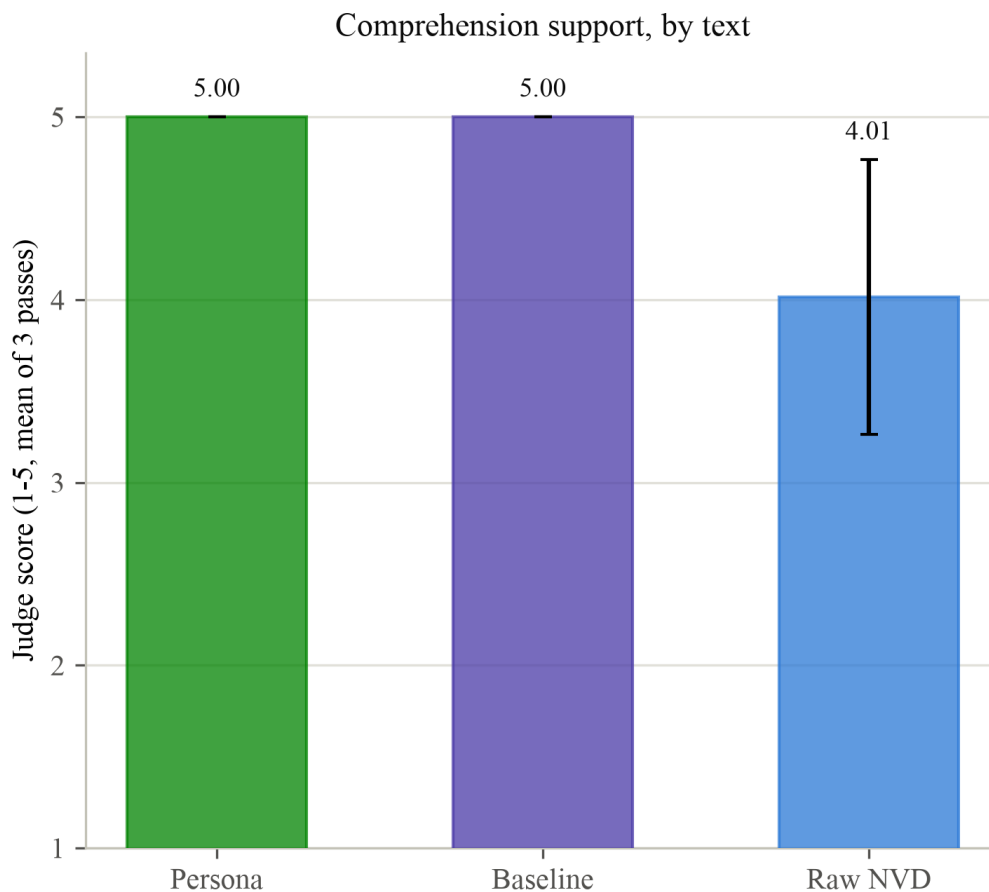


Figure 4.4: Independent judge comprehension support scores for the three texts (GPT-4.1, temperature 0, mean of three passes).

4.3.2 Faithfulness

Faithfulness was judged against the source. The pattern was the reverse of comprehension. The raw NVD descriptions scored a mean of 5.00 with a standard deviation of 0.00,

which follows from the design, since a description scored against itself is fully faithful by construction. The persona summaries scored a mean of 3.18 and the baseline summaries a mean of 3.04. Measured as a paired difference against the raw description, the persona summaries scored 1.82 points lower and the baseline summaries 1.96 points lower. The faithfulness reference was the raw NVD description field alone, which does not include the CVSS attack and impact fields or the exploitation data that the generator was given.

To test whether this narrow reference explained the gap, faithfulness was scored a second time against an expanded reference. The expanded reference added the CVSS attack and impact fields that the generator was given, drawn from the same NVD record, while the rest of the design was held constant. Under the expanded reference the persona summaries scored a mean of 3.82 and the baseline summaries a mean of 3.68, each 0.64 points higher than under the description-only reference, giving a paired effect size of $d = 0.89$ and $d = 0.88$. The raw NVD control was unchanged at 5.00. No CVE scored lower under the expanded reference in either condition. Figure 4.5 shows the change for each CVE. The faithfulness scores under the expanded reference are shown in full in Figure B.4.

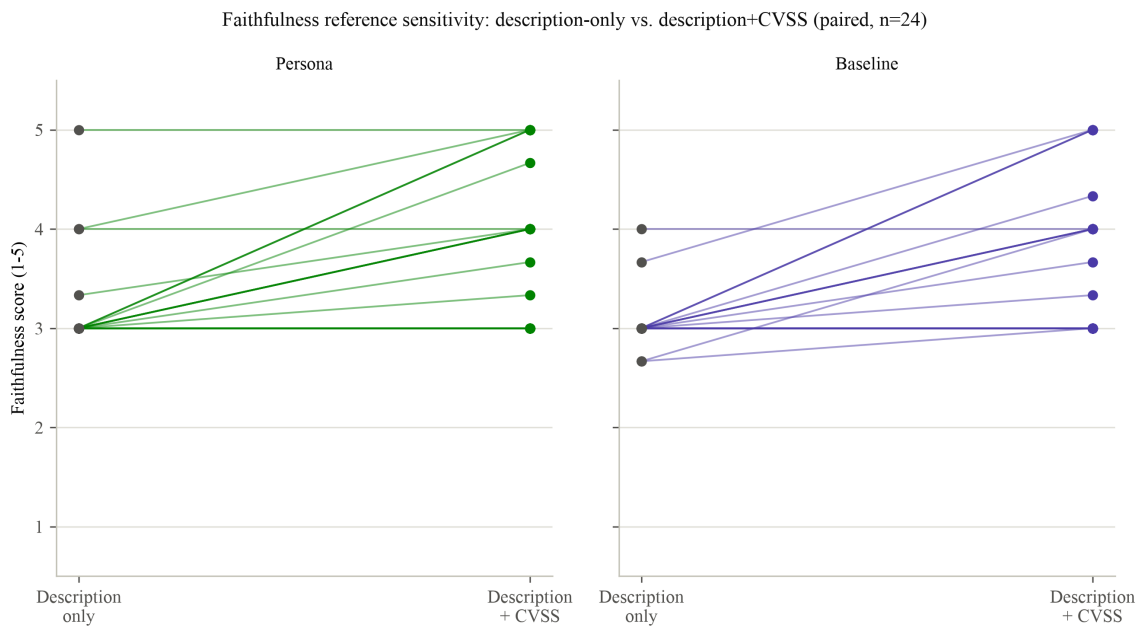


Figure 4.5: Per-CVE change in faithfulness score from the description-only reference to the description and CVSS reference, for the persona and baseline summaries.

Full judge scores for both dimensions are given in Table B.5 and Figure B.3.

4.3.3 Scoring Reliability

To check that the scores were stable and not an artefact of a single run, each text was scored three times on each dimension. The scores were stable. Of the 144 text and dimension combinations, only seven showed any variation across the three passes, and in

every case the variation was a single point. The full set of these cases is given in Table B.4.

4.4 Human Study

The third evaluation method measured comprehension directly, with participants drawn from the intended user group of technically capable readers without security training. The design is described in Section 3.4.4. Participants were shown vulnerability records and answered questions on them, so comprehension was measured from their answers rather than inferred from the text. This section reports the results.

4.4.1 Participants

Twenty-four people opened the survey and all consented. Of these, sixteen reached at least one vulnerability record, and the rest left before answering any. Fifteen answered a full block of four records, and one answered two of the four. The sixteen who started were spread across all six survey versions, with between two and four people on each.

One respondent reported no technical background, which places them outside the group the study is about. Their answers are held out of the comparison and reported here on their own. They answered every question but scored 16.7%, well below every other participant, which is consistent with their lack of technical background. This score is not part of any result that this paper reports.

The main analysis therefore uses the fifteen participants with a technical background. The sample is small, so the results below show which way the evidence points rather than providing a conclusive answer to the research question.

4.4.2 Comprehension Accuracy

Comprehension was measured as the share of multiple-choice questions participants answered correctly. Across all questions, participants scored 83.9% on the raw NVD descriptions and 88.5% on the summaries, a gap of 4.6 points in favour of the summary. Before the one non-technical respondent was set aside, the same gap was 2.5 points, 77.8% against 80.2%, so removing a reader from outside the target group widened the difference rather than creating it. Both are small-sample results and show which way the evidence points.

Figure 4.6 shows the two conditions side by side. Table 4.1 breaks the same result down by the three question types.

The pattern differs across the three question types. The summary scored higher on what

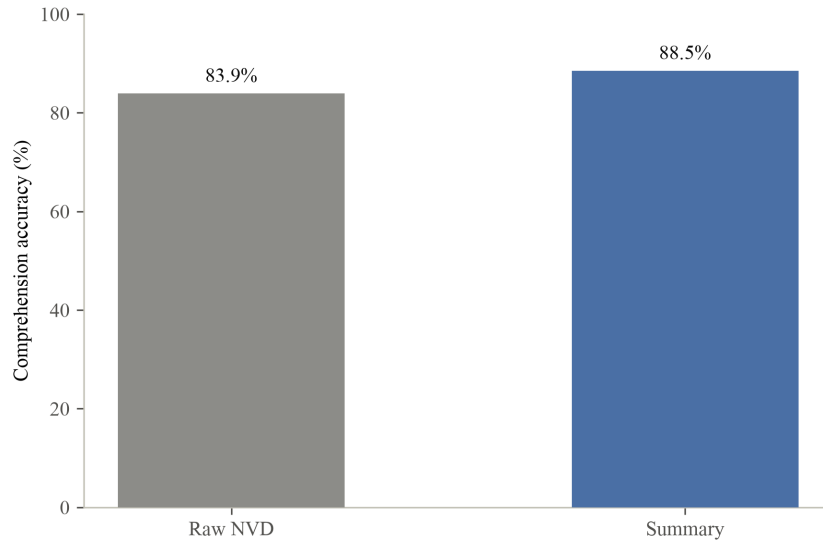


Figure 4.6: Comprehension accuracy on the raw NVD descriptions and the summaries, technical-background sample ($n = 15$).

Table 4.1: Comprehension accuracy by question type and condition ($n = 15$).

Question type	NVD	Summary
What is vulnerable	82.8%	89.7%
How it is exploited	93.1%	89.7%
Fix scope	75.9%	86.2%

is vulnerable and on the fix scope. The two conditions were close on how the vulnerability is exploited, where the raw description came out slightly ahead. Fix scope was the weakest question type in both conditions. The most common mistake was not identifying what was vulnerable but identifying which version resolved the issue, in both forms.

Two questions had problems that came from the question itself, not the condition. One asked about an affected component and was answered wrongly in half of its appearances across both conditions, even though both texts state the answer plainly, which points to the term being easy to misread. A second, asked for two records, concerned a fix version that neither the raw description nor the summary actually names. One participant noted this in the free-text field. Most people still picked the intended answer by ruling out the others, so its recorded accuracy looks normal, but the question does not test comprehension of the text shown. Both are treated as limitations of the instrument and are discussed in Chapter 5.

One further response was fast enough to be flagged, as a full block of four records and twenty questions were finished in under two minutes. It was the only technical-background response below 75%. It is kept in the figures above, since there is no independent basis for removing it, but it is noted here as likely rushed answering rather than genuine difficulty.

4.4.3 Comprehension by Familiarity with Vulnerability Information

The survey recorded how often each participant works with CVE records and CVSS scores. Splitting the results this way shows where the summary made the most difference. Table 4.2 gives accuracy by familiarity group.

Table 4.2: Comprehension accuracy by familiarity with vulnerability records ($n = 15$)

Familiarity with CVE/CVSS records	NVD	Summary	Accuracy (both)
Never worked with them ($n = 7$)	78.6%	85.7%	82.1%
Seen them occasionally ($n = 5$)	86.7%	86.7%	86.7%
Work with them from time to time ($n = 3$)	93.3%	100%	96.7%

Accuracy increased the more familiar a person was with CVE information. From 82.1% for those who had never worked with these records to 86.7% for those who had seen them occasionally to 96.7% for those who work with them from time to time. This is the expected direction, since people who read vulnerability records more often understand them more easily, whatever form the text takes.

The summary version of the vulnerability information helped some groups more than others. The summary helped the least-familiar group the most, as they scored 78.6% on the raw description against 85.7% on the summary, a gap of 7.1 points. The middle group

showed no gap at all. The participants least familiar with vulnerability information are the closest match to the people the tool is meant to help, so the summary appearing to help them most is the pattern the study hoped to find. The least-familiar group is only seven people, so this is read as suggestive evidence rather than a definitive result.

4.4.4 Clarity and Confidence

After each record, participants rated how clear the text was and how confident they felt in their understanding, on a five-point Likert scale. Table 4.3 gives the mean ratings for each condition.

Table 4.3: Mean clarity and confidence ratings by condition, five-point scale, technical-background sample ($n = 15$).

Rating	NVD	Summary
Clarity	3.69	4.17
Confidence	3.79	4.10

Both ratings were higher for the summary. Clarity averaged 3.69 for the raw description and 4.17 for the summary, and confidence averaged 3.79 against 4.10. Participants found the summaries clearer and felt more sure of their understanding when reading them.

These ratings did not always line up with how well participants actually scored. The group that worked with vulnerability records most often scored highest on comprehension but gave the lowest clarity and confidence ratings. The same mismatch appears at the level of individual records and across the wider CVE sets. How clear participants found a text and how well they understood it were not measuring the same thing. What this means for the study is further discussed in Chapter 5.

4.5 Summary of Findings

This chapter reported the results of the three evaluation methods.

The automated metrics showed that both summary conditions were more readable than the raw NVD descriptions, with a large and consistent reduction in Dale-Chall score, and that readability did not improve for a small number of CVEs whose source descriptions were already among the most readable in the sample. The summaries stayed close to the source in meaning, with high BERTScore and low ROUGE across both conditions. The persona summaries were longer than the baseline summaries, which was the clearest difference between the two conditions.

The human study measured comprehension directly. Participants scored higher on the summaries than on the raw NVD descriptions, and rated the summaries clearer and more confidence-inspiring, though the sample was small and the differences are read as a first indication rather than proof. The summary appeared to help the least-familiar readers most, the group closest to the intended users. Two questions were found to test the instrument rather than the text and are noted as limitations. Self-reported clarity did not correspond with measured comprehension across the data.

The independent judge scored both summary conditions at the top of the comprehension scale, above the raw NVD descriptions, and could not separate the two conditions on this dimension. On faithfulness the summaries scored below the raw NVD control under the description-only reference. When the reference was expanded to include the CVSS fields the generator was given, both conditions scored higher, by the same margin and with no CVE scoring lower, while the control was unchanged.

Chapter 5

Discussion

Appendix A

Corpus and Evaluation Sample Data

Table A.1: Post-filter record counts by severity (all years)

Severity	Records	Share
CRITICAL	17,629	11.3%
HIGH	57,397	36.8%
MEDIUM	74,404	47.7%
LOW	6,654	4.3%
Total	156,084	100%

Table A.2: Record counts by year, before and after filtering

Year	Before filter	CRITICAL	HIGH	MEDIUM	LOW	After filter total
2020	21,050	1,823	5,784	7,479	502	15,588
2021	23,428	2,301	7,445	8,932	720	19,398
2022	27,516	3,329	8,404	11,034	825	23,592
2023	31,204	3,232	8,528	13,472	1,146	26,378
2024	39,132	2,603	9,783	15,022	1,358	28,766
2025	44,651	2,332	9,896	11,753	1,494	25,475
2026	26,104	2,009	7,557	6,712	609	16,887
Total	213,085	17,629	57,397	74,404	6,654	156,084

Table A.3: Corpus composition against source pool

Severity	Pool records	Pool %	Corpus records	Corpus %
CRITICAL	17,629	11.3%	1,355	11.3%
HIGH	57,397	36.8%	4,413	36.8%
MEDIUM	74,404	47.7%	5,720	47.7%
LOW	6,654	4.3%	512	4.3%
Total	156,084		12,000	

Table A.4: Evaluation sample composition

Cell	CVE ID	Severity	KEV	EPSS	Attack vector	Vendor
A	CVE-2020-8010	CRITICAL	No	0.4867	NETWORK	Broadcom
A	CVE-2023-50919	CRITICAL	No	0.4780	NETWORK	GL.iNet
A	CVE-2023-29119	CRITICAL	No	0.0033	ADJACENT_NETWORK	EnelX
A	CVE-2021-23894	CRITICAL	No	0.0224	ADJACENT_NETWORK	McAfee
B	CVE-2024-21887	CRITICAL	Yes	1.0000	NETWORK	Ivanti
B	CVE-2021-26084	CRITICAL	Yes	1.0000	NETWORK	Atlassian
B	CVE-2024-3400	CRITICAL	Yes	1.0000	NETWORK	Palo Alto Networks
B	CVE-2021-42013	CRITICAL	Yes	0.9996	NETWORK	Apache
C	CVE-2020-8958	HIGH	No	0.4664	NETWORK	GPON ONU
C	CVE-2023-43661	HIGH	No	0.4690	NETWORK	(multiple)
C	CVE-2021-21974	HIGH	No	0.4506	ADJACENT_NETWORK	VMware
C	CVE-2021-22717	HIGH	No	0.3891	NETWORK	Schneider Electric
D	CVE-2020-8260	HIGH	Yes	0.9648	NETWORK	Ivanti
D	CVE-2023-44221	HIGH	Yes	0.7493	NETWORK	SonicWall
D	CVE-2020-8655	HIGH	Yes	0.5726	LOCAL	EyesOfNetwork
D	CVE-2023-21608	HIGH	Yes	0.6148	LOCAL	Adobe
E	CVE-2022-3062	MEDIUM	No	0.3740	NETWORK	Simple File List
E	CVE-2023-0157	MEDIUM	No	0.3246	NETWORK	UpdraftPlus
E	CVE-2021-30970	MEDIUM	No	0.1345	LOCAL	Apple
E	CVE-2024-1781	MEDIUM	No	0.1469	ADJACENT_NETWORK	TOTOLINK
F	CVE-2021-37976	MEDIUM	Yes	0.1990	NETWORK	Google
F	CVE-2022-28810	MEDIUM	Yes	0.7042	NETWORK	Zoho
F	CVE-2021-22204	MEDIUM	Yes	0.9998	LOCAL	ExifTool
F	CVE-2022-40765	MEDIUM	Yes	0.1048	ADJACENT_NETWORK	Mitel

Table A.5: Nearest-neighbour cosine distance across the 24 evaluation CVEs

Statistic	Distance
Minimum	0.0068
Lower quartile	0.2072
Median	0.3418
Upper quartile	0.4032
Maximum	0.6224

Appendix B

Findings and Evaluation Supplementary Data

Table B.1: CVEs where the summary scored a higher (harder) Dale-Chall score than the raw NVD description it was generated from.

CVE	Condition	Summary DC	NVD DC	Difference
CVE-2021-42013	Baseline	11.79	11.51	+0.27
CVE-2021-42013	Persona	11.75	11.51	+0.24
CVE-2023-43661	Baseline	11.58	11.53	+0.04
CVE-2022-3062	Baseline	11.61	11.07	+0.54
CVE-2022-3062	Persona	11.50	11.07	+0.43
CVE-2024-1781	Baseline	11.80	10.30	+1.49
CVE-2024-1781	Persona	12.07	10.30	+1.77

Table B.2: Descriptive statistics for the automated metrics, both prompt conditions, across the 24 evaluation CVEs.

Metric	Persona			Baseline		
	Mean	Median	SD	Mean	Median	SD
ROUGE-1 (F)	0.23	0.22	0.08	0.24	0.23	0.07
ROUGE-2 (F)	0.13	0.12	0.06	0.12	0.11	0.05
ROUGE-L (F)	0.16	0.15	0.05	0.16	0.15	0.05
BERTScore precision	0.82	0.82	0.02	0.82	0.82	0.01
BERTScore recall	0.91	0.90	0.02	0.91	0.91	0.02
BERTScore F1	0.86	0.86	0.01	0.86	0.86	0.01
Dale-Chall (summary)	11.90	11.98	0.35	11.96	11.88	0.42
Word count	279.54	282.50	20.21	266.08	269.00	27.57

Table B.3: Paired differences between the persona and baseline conditions across the 24 evaluation CVEs, with paired Cohen’s d .

Metric	Mean diff	Median diff	SD diff	Cohen’s d
ROUGE-1 (F)	−0.01	−0.00	0.03	−0.34
ROUGE-2 (F)	0.00	−0.00	0.03	0.13
ROUGE-L (F)	−0.01	−0.00	0.02	−0.32
BERTScore precision	−0.00	−0.00	0.01	−0.22
BERTScore recall	−0.00	−0.00	0.01	−0.04
BERTScore F1	−0.00	−0.00	0.01	−0.19
Dale-Chall	−0.06	−0.07	0.25	−0.24
Word count	13.46	14.50	18.08	0.74

Table B.4: The seven text and dimension combinations that varied across the three judge passes. All other combinations scored identically on every pass.

CVE	Text	Dimension	Scores	Mean
CVE-2021-21974	Raw NVD	comprehension	4, 4, 5	4.33
CVE-2021-37976	Baseline	faithfulness	2, 3, 3	2.67
CVE-2021-42013	Raw NVD	comprehension	5, 4, 5	4.67
CVE-2022-3062	Baseline	faithfulness	4, 4, 3	3.67
CVE-2023-29119	Baseline	faithfulness	2, 3, 3	2.67
CVE-2024-1781	Raw NVD	comprehension	3, 4, 3	3.33
CVE-2024-3400	Persona	faithfulness	3, 3, 4	3.33

Table B.5: Independent judge scores across the 24 evaluation CVEs, both dimensions and three texts (GPT-4.1, temperature 0, mean of three passes). Faithfulness is under the description-only reference.

Dimension	Text	Mean	Median	SD	Range
Comprehension	Persona	5.000	5.000	0.000	5–5
Comprehension	Baseline	5.000	5.000	0.000	5–5
Comprehension	Raw NVD	4.014	4.000	0.752	3–5
Faithfulness	Persona	3.181	3.000	0.481	3–5
Faithfulness	Baseline	3.042	3.000	0.266	2.67–4
Faithfulness	Raw NVD	5.000	5.000	0.000	5–5

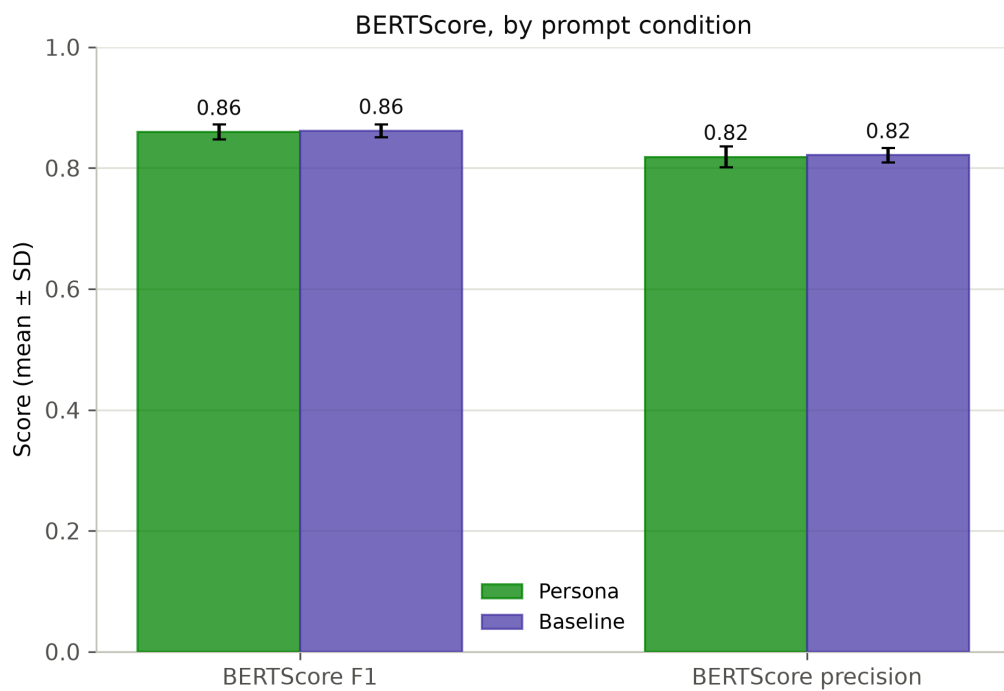


Figure B.1: BERTScore F1 and precision for the persona and baseline summaries.

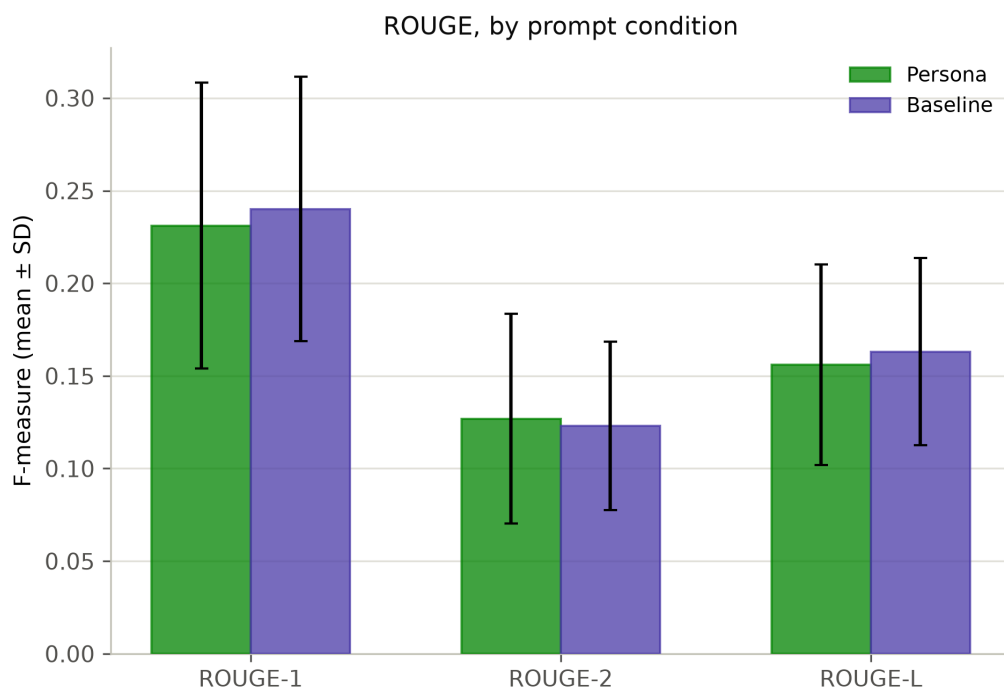


Figure B.2: ROUGE-1, ROUGE-2 and ROUGE-L for the persona and baseline summaries.

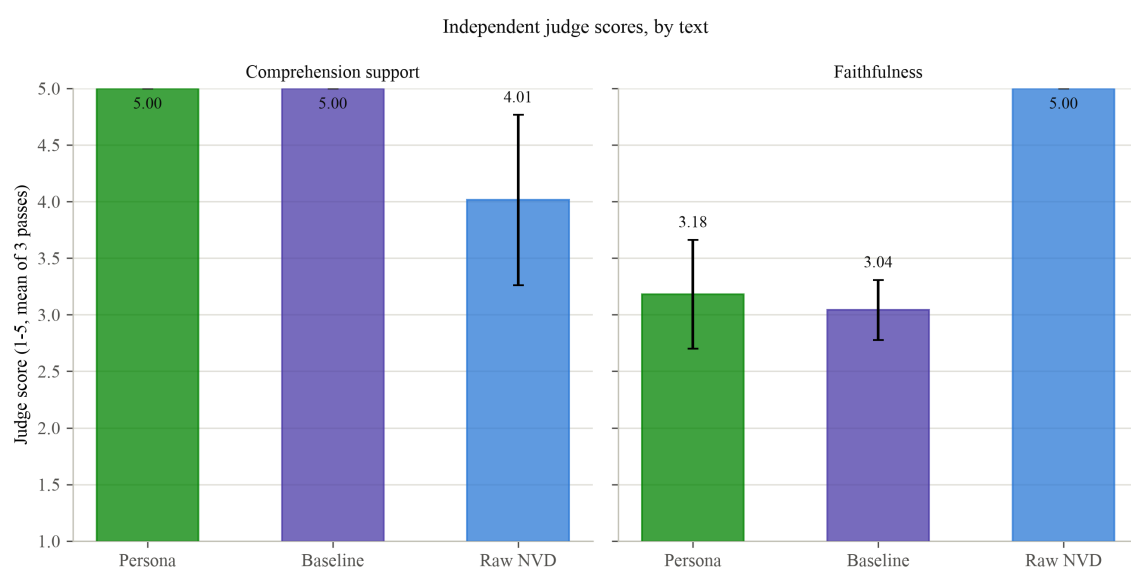


Figure B.3: Independent judge scores for comprehension support and faithfulness, across the three texts (GPT-4.1, temperature 0, mean of three passes). Faithfulness is under the description-only reference.

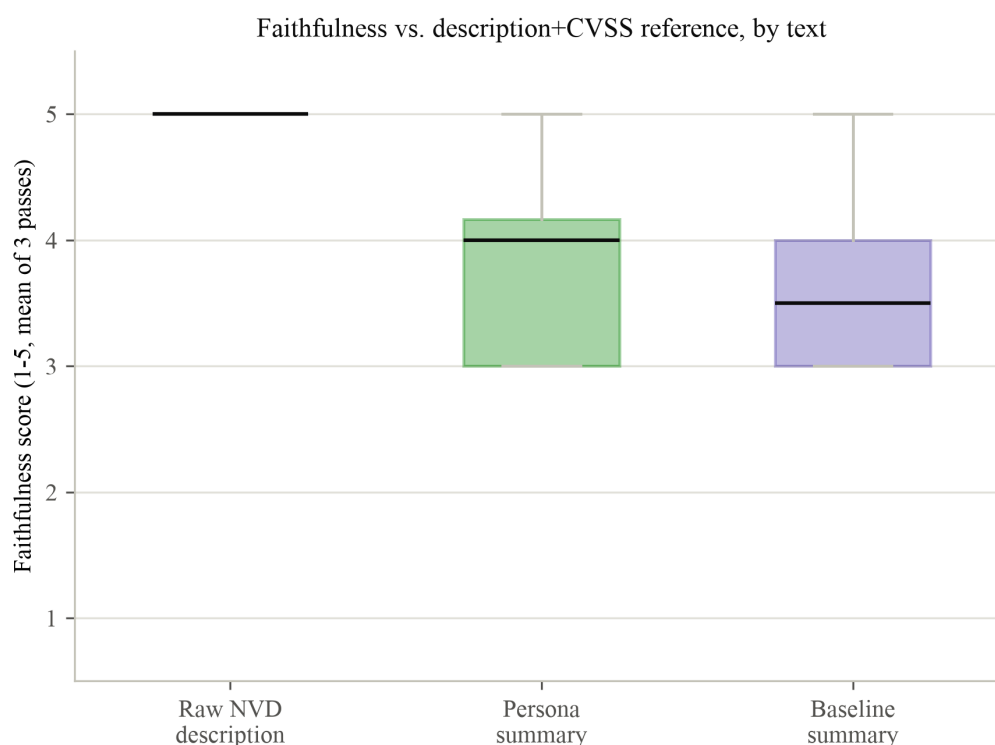


Figure B.4: Faithfulness scores under the description and CVSS reference, for the three texts (GPT-4.1, temperature 0, mean of three passes).

Bibliography

Afzalzada, A. (2026), ‘Stingrai inc.’.

URL: <https://www.stingrai.io/blog/vulnerability-statistics-2026>

Allodi, L., Banescu, S., Femmer, H. & Beckers, K. (2018), Identifying relevant information cues for vulnerability assessment using CVSS, *in* ‘Proceedings of the Eighth ACM Conference on Data and Application Security and Privacy (CODASPY ’18)’, ACM, New York, NY, USA, pp. 119–126.

Allodi, L., Cremonini, M., Massacci, F. & Shim, W. (2020), ‘Measuring the accuracy of software vulnerability assessments: experiments with students and professionals’, *Empirical Software Engineering* **25**(2), 1063–1094.

Alloza-García, S., García-Magariño, I. & Lacuesta, R. (2025), ‘Explainable artificial intelligence system for guiding companies and users in detecting and fixing multimedia web vulnerabilities on mcs contexts’, *Future Internet* **17**, 524.

Alqahtani, N. & Almukaynizi, M. (2025), ‘Vulnscore: A deployed system for patch prioritization combining human input and temporal threat intelligence: Vulnscore: A deployed system for patch prioritization...’, *Int. J. Inf. Secur.* **25**(1).

URL: <https://doi.org/10.1007/s10207-025-01164-3>

Carreira, C., Mendes, A., Ferreira, J. F. & Christin, N. (2025), ‘A systematic review of security communication strategies: Guidelines and open challenges’.

URL: <https://arxiv.org/abs/2504.02109>

Chopra, S., Ahmad, H., Goel, D. & Szabo, C. (2026), ‘Chatnvd: Advancing cybersecurity vulnerability assessment with large language models’, *IEEE Access* **14**, 18595–18610.

Chung, M.-H. M., Yang, Y. A., Wang, L., Cento, G., Jerath, K., Taank, P., Raman, A., Chan, J. H. & Chignell, M. H. (2023), ‘Enhancing cybersecurity situation awareness through visualization: A usb data exfiltration case study’, *Heliyon* **9**(1), e13025.

Dale, E. & Chall, J. S. (1948), ‘A formula for predicting readability’, *Educational Research Bulletin* **27**(1), 11–28.

URL: <http://www.jstor.org/stable/1473169>

-
- de Jesus Coelho da Silva, G. & Westphall, C. B. (2024), ‘A survey of large language models in cybersecurity’.
URL: <https://arxiv.org/abs/2402.16968>
- Devendra, I., Wijesiriwardana, C. & Wimalaratne, P. (2025), ‘State-of-the-art in software security visualization: A systematic review’. arXiv:2509.20385.
URL: <https://arxiv.org/abs/2509.20385>
- Endsley, M. R. (1995), ‘Toward a theory of situation awareness in dynamic systems’, *Human Factors: the Journal of the Human Factors and Ergonomics Society* **37**(1), 32–64.
URL: <https://journals.sagepub.com/doi/10.1518/001872095779049543>
- Forum of Incident Response and Security Teams (2019), ‘Common vulnerability scoring system version 3.1: Specification document’.
URL: <https://www.first.org/cvss/v3.1/specification-document>
- Forum of Incident Response and Security Teams (2026), ‘First releases 2026 vulnerability report, projecting record-breaking common vulnerabilities and exposures’.
URL: <https://www.first.org/newsroom/releases/20260211>
- Galanska, K., Kruzikova, A., Murumaa, M. P., Matyáš, V. & Just, M. (2025), ‘From reports to actions: Bridging the customer usability gap in penetration testing’, *IEEE Access* **13**, 73975–73986.
- Hagen, R. A., Øverlier, L. & Helkala, K. (2025), ‘Human factors in ai-driven cybersecurity: Cognitive biases and trust issues’, *Digital Threats* **6**(4).
URL: <https://doi.org/10.1145/3759260>
- Haney, J. M. & Lutters, W. G. (2018), “it’s Scary...It’s Confusing...It’s dull”: How cybersecurity advocates overcome negative perceptions of security, in ‘Fourteenth Symposium on Usable Privacy and Security (SOUPS 2018)’, USENIX Association, Baltimore, MD, pp. 411–425.
URL: <https://www.usenix.org/conference/soups2018/presentation/haney-perceptions>
- Hibshi, H., Breaux, T. D., Riaz, M. & Williams, L. (2016), ‘A grounded analysis of experts’ decision-making during security assessments’, *Journal of Cybersecurity* **2**(2), 147–163.
- Hussain, M. (2025), Exploring the Collaboration Between AI and Human Expertise in Risk Management for Improved Decision-Making in Software Product Security: A Qualitative Study, PhD thesis, University of the Cumberlands.
- Jacobs, J., Romanosky, S., Edwards, B., Adjerd, I. & Roytman, M. (2021), ‘Exploit prediction scoring system (epss)’, *Digital Threats* **2**(3).
URL: <https://doi.org/10.1145/3436242>

-
- Jawad, A., Assal, H. & Jaskolka, J. (2024), “‘i’m getting information that i can act on now”: Exploring the level of actionable information in tool-generated threat reports’, *Proceedings of the 2024 European Symposium on Usable Security* p. 172–186.
- Jiang, L., Jayatilaka, A., Nasim, M., Grobler, M., Zahedi, M. & Babar, M. A. (2022), ‘Systematic literature review on cyber situational awareness visualizations’, *IEEE Access* **10**, 57525–57554.
- Johnson, O., Fomina, A., Krishnamurthy, R., Chaudhari, V., Shanmuganathan, R. & Bodden, E. (2025), ‘Explaining software vulnerabilities with large language models’.
- Jung, B., Li, Y. & Bechor, T. (2022), ‘Cavp: A context-aware vulnerability prioritization model’, *Computers & Security* **116**, 102639.
- Kincaid, P., Fishburne, R. P., Rogers, R. L. & Chissom, B. S. (1975), Derivation of new readability formulas (automated readability index, fog count and flesch reading ease formula) for navy enlisted personnel.
URL: <https://api.semanticscholar.org/CorpusID:61131325>
- Lewis, P., Perez, E., Piktus, A., Petroni, F., Karpukhin, V., Goyal, N., Küttler, H., Lewis, M., Yih, W.-t., Rocktäschel, T., Riedel, S. & Kiela, D. (2020), Retrieval-augmented generation for knowledge-intensive nlp tasks, *in* ‘Proceedings of the 34th International Conference on Neural Information Processing Systems’, NIPS ’20, Curran Associates Inc., Red Hook, NY, USA.
- Lin, C.-Y. (2004), ROUGE: A package for automatic evaluation of summaries, *in* ‘Text Summarization Branches Out’, Association for Computational Linguistics, Barcelona, Spain, pp. 74–81.
URL: <https://aclanthology.org/W04-1013/>
- McClanahan, K., Elder, S., Uwibambe, M. L., Liu, Y., Heng, R. & Li, Q. (2024), ‘When chatgpt meets vulnerability management: The good, the bad, and the ugly’, *IEEE* .
- National Institute of Standards and Technology (2024), ‘National vulnerability database: General information’.
URL: <https://nvd.nist.gov/general>
- NIST (2026), ‘Nist updates nvd operations to address record cve growth — nist’.
URL: <https://www.nist.gov/news-events/news/2026/04/nist-updates-nvd-operations-address-record-cve-growth>
- Pekarić, I., Zech, P. & Mattson, T. (2025), ‘Llms in cybersecurity: Friend or foe in the human decision loop?’.
URL: <https://arxiv.org/abs/2509.06595>

-
- Reynolds, S. L., Mertz, T., Arzt, S. & Kohlhammer, J. (2021), User-centered design of visualizations for software vulnerability reports, in ‘2021 IEEE Symposium on Visualization for Cyber Security (VizSec)’, pp. 68–78.
- Schüring, B. L., Herrmann, M., Specht, A., Ehl, M., Elsofi, D. A. A., Großer, K., Jürjens, J. & Schneider, K. (2025), ‘Generating context-aware learning materials for software security via llm agents and traceability’, *2025 IEEE 33rd International Requirements Engineering Conference Workshops (REW)* p. 249–258.
URL: <https://ieeexplore.ieee.org/document/11190192>
- Shen, X., Cheng, W., Chen, Y., Li, Z., Gu, Y., Wang, L., Zhao, W., Sun, D. & Wang, J. (2025), ‘Aeas: Actionable exploit assessment system’.
URL: <https://arxiv.org/abs/2509.17832>
- Shimizu, N. & Hashimoto, M. (2026), ‘Vulnerability management chaining: An integrated framework for efficient cybersecurity risk prioritization’, *IEEE Access* **14**, 31407–31424.
URL: <http://dx.doi.org/10.1109/ACCESS.2026.3665768>
- Siewruk, G. & Bondaruk, T. (2026), ‘Severity is not exploitability: A simple taxonomy and context score for better cve triage’, *International Journal of Electronics and Telecommunications* **72**(Vol 72 No. 1(2026)), 1–7.
- Smith, J., Do, L. N. Q. & Murphy-Hill, E. (2020), Why can’t johnny fix vulnerabilities: a usability evaluation of static analysis tools for security, in ‘Proceedings of the Sixteenth USENIX Conference on Usable Privacy and Security’, SOUPS’20, USENIX Association, USA.
- Tanis, N., Iqbal, S. & Wysopal, C. (2025), 2025 state of software security: a new view of maturity, Technical report, Veracode.
- Technologies, S. (2024), ‘The cybersecurity landscape of 2024: Key insights from the annual vuln’.
URL: <https://www.secpod.com/learn/security-research/the-cybersecurity-landscape-of-2024-key-insights-from-the-annual-vulnerability-report>
- Thomas, T. W., Tabassum, M., Chu, B. & Lipford, H. (2018), Security during application development: an application security expert perspective, in ‘Proceedings of the 2018 CHI Conference on Human Factors in Computing Systems’, CHI ’18, Association for Computing Machinery, New York, NY, USA, p. 1–12.
URL: <https://doi.org/10.1145/3173574.3173836>
- Torkamani, M. J., NG, J., Mehrotra, N., Chandramohan, M., Krishnan, P. & Purandare, R. (2025), ‘Streamlining security vulnerability triage with large language models’.
URL: <https://arxiv.org/abs/2501.18908>

Veracode (2026), ‘2026 state of software security - prioritize, protect, prove’.

URL: <https://www.veracode.com/wp-content/uploads/2026-State-of-Software-Security-Report.pdf>

Walkowski, M., Oko, J. & Sujecki, S. (2021), ‘Vulnerability management models using a common vulnerability scoring system’, *Applied Sciences* **11**(18), 8735.

Watson, S. & Lipford, H. R. (2017), A proposed visualization for vulnerability scan data, in ‘USENIX Workshop on Usable Security (SOUPS)’, USENIX Association.

Xiao, S., Liu, S., Zhou, W., Wu, J., He, X., Lin, Z. & Xie, Q. (2026), ‘When does persona prompting actually help? a retrieval and metric analysis of expert role injection in llms’.

URL: <https://arxiv.org/abs/2605.29420>

Zhang, T., Kishore, V., Wu, F., Weinberger, K. Q. & Artzi, Y. (2020), ‘Bertscore: Evaluating text generation with bert’.

URL: <https://arxiv.org/abs/1904.09675>

Zhao, W. X., Zhou, K., Li, J., Tang, T., Wang, X., Hou, Y., Min, Y., Zhang, B., Zhang, J., Dong, Z., Du, Y., Yang, C., Chen, Y., Chen, Z., Jiang, J., Ren, R., Li, Y., Tang, X., Liu, Z., Liu, P., Nie, J.-Y. & Wen, J.-R. (2023), ‘A survey of large language models’, *arXiv preprint arXiv:2303.18223*.

URL: <https://arxiv.org/abs/2303.18223>